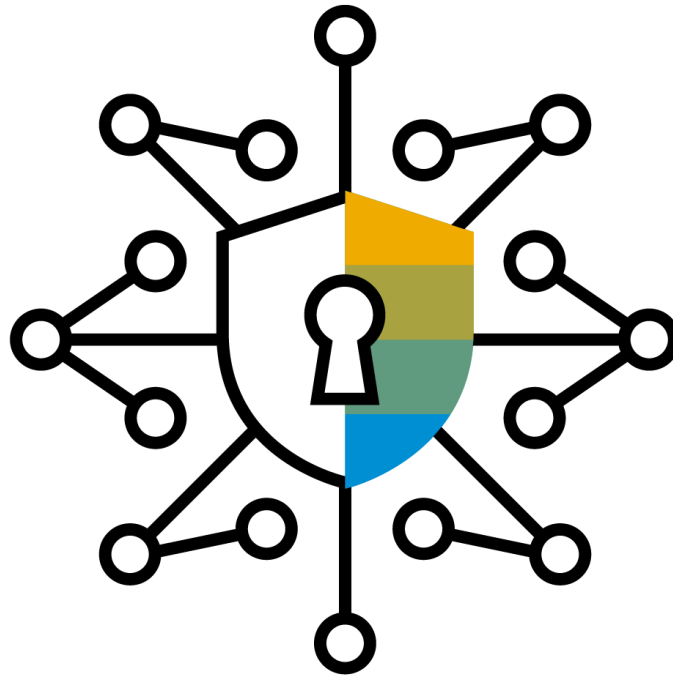


SAP Security Baseline Template

SAP Security Baseline Template

Version 2.6



The structure of the template is based on the SAP Secure Operations Map:

Organization	Awareness	Security Governance	Risk Management	
Process	Regulatory Process Compliance	Data Privacy & Protection	Audit & Fraud Management	
Application	User & Identity Management	Authentication & Single Sign-On	Roles & Authorizations	Custom Code Security
System	Security Hardening	Secure SAP Code	Security Monitoring & Forensics	
Environment	Network Security	Operating System & Database Security	Client Security	

SAP Security Baseline Template

Change History

The change markers in the text show the difference to version 2.5

Date	Version	Change
11-Jul-2025	2.6	- Minor text enhancements - New parameter settings based on updated ECS Note 3250501 - New secure default settings in S/4HANA 2025 <u>New critical authorizations for ABAP</u>
08-Apr-2024	2.5	- New requirements about trusting relations between systems - New secure default settings in S/4HANA 2023 and BW/4HANA 2023
24-Feb-2023	2.4.1	Corrections of typos and minor text enhancements
27-Dec-2022	2.4	- Updated requirements for BTP - Alignment with updated security settings in S/4HANA as described in note 2926224 - Partly rework of chapter 3
16-Nov-2021	2.3	New requirements for BTP (aligned with corresponding SOS checks)
29-Oct-2020	2.2	Alignment with security settings in S/4HANA as described in note 2926224
13-Oct-2020	2.1	Minor adjustments and alignment with Configuration Validation package
17-Feb-2020	2.0	New version published

SAP Security Baseline Template

TABLE OF CONTENTS

1	Overview, Requirements and Guidelines	9
1.1	Purpose of this template.....	9
1.2	Structure	9
1.3	Support	10
2	Regulations	11
2.1	Environment	12
2.1.1	Network Security	12
2.1.2	Operating System and Database Security	12
<i>USRCTR: User Control of Action – Others.....</i>		<i>12</i>
USRCTR-O: User Control of Action – Others		12
2.1.3	Client Security	13
2.2	System	13
2.2.1	Security Hardening.....	13
<i>CHANGE: Protect Production System against changes.....</i>		<i>13</i>
CHANGE-A: Protect Production System against changes – ABAP		13
<i>DISCL: Information Disclosure</i>		<i>14</i>
DISCL-A: Information Disclosure – ABAP		14
DISCL-H: Information Disclosure – HANA.....		14
DISCL-J: Information Disclosure – Java.....		14
DISCL-O: Information Disclosure – Web Dispatcher		14
<i>FILE: Directory Traversal Protection</i>		<i>15</i>
FILE-A: Directory Traversal Protection – ABAP.....		15
<i>MSGSRV: Message Server Security.....</i>		<i>15</i>
MSGSRV-A: Message Server Security.....		15
MSGSRV-J: Message Server Security		16
<i>NETCF: Secure Network Configuration.....</i>		<i>16</i>
NETCF-A: Secure Network Configuration – ABAP		16
NETCF-H: Secure Network Configuration HANA		17
NETCF-P: Secure Network Configuration – BTP.....		17
<i>NOTEST: No Testing Functionality in Production.....</i>		<i>18</i>
NOTEST-J: No Testing Functionality in Production – Java		18
<i>OBSCNT: Obsolete Clients/Tenants</i>		<i>18</i>
OBSCNT-A: Obsolete Clients in ABAP		18
OBSCNT-H: Obsolete Tenants in HANA.....		18
<i>SCRIPT: Scripting Protection</i>		<i>18</i>
SCRIPT-A: Scripting Protection – ABAP		18
<i>SESS: Session Protection.....</i>		<i>19</i>

SAP Security Baseline Template

SESS-J: Session Protection – Java.....	19
<i>TRACES: Critical Data in trace files</i>	<i>19</i>
TRACES-H: Critical Data in trace files – HANA.....	19
<i>USRCTR: User Control of Action</i>	<i>19</i>
USRCTR-A: User Control of Action – ABAP.....	19
2.2.2 Secure SAP Code	20
<i>SECUPD: Regular Security Updates.....</i>	<i>20</i>
SECUPD-A: Regular Security Updates – ABAP	20
SECUPD-J: Regular Security Updates – Java.....	20
SECUPD-H: Regular Security Updates – HANA	20
SECUPD-O: Regular Security Updates – SAPGUI.....	20
SECUPD-P: Regular Security Updates – BTP	20
<i>FEATAC: Feature Activation</i>	<i>20</i>
FEATAC-P: Feature Activation – BTP	20
2.2.3 Security Monitoring and Forensics	21
2.3 Application.....	21
2.3.1 User and Identity Management.....	21
<i>SELFRG: No Self-Registration of Users.....</i>	<i>21</i>
SELFRG-J: No Self-Registration of Users	21
<i>STDUSR: Standard Users</i>	<i>21</i>
STDUSR-A: Standard Users in ABAP	21
STDUSR-H: Standard Users in HANA.....	22
<i>USRTYP: Types of Users</i>	<i>22</i>
USRTYP-A: User types of reference users in ABAP	22
USRTYP-P: Types of Users in BTP	22
<i>USRCHAR: Allowed character sets for user names</i>	<i>23</i>
USRCHAR-A: Allowed character sets for user names in ABAP	23
2.3.2 Authentication and Single Sign-On.....	23
<i>NETENC: Encryption of Network Connections.....</i>	<i>23</i>
NETENC-A: Encryption of Network Connections – ABAP	23
NETENC-O: Encryption of Network Connections – Web Dispatcher.....	24
<i>PWDPOL: Password Policy</i>	<i>24</i>
PWDPOL-A: Password Policy – ABAP	24
PWDPOL-J: Password Policy – Java	26
PWDPOL-H: Password Policy – HANA	26
<i>RFCGW: RFC Gateway Security</i>	<i>27</i>
RFCGW-A: RFC Gateway Security (part of application server ABAP)	27
RFCGW-J: RFC Gateway Security (part of application server Java).....	28
RFCGW-O: RFC Gateway Security (stand-alone).....	28
<i>TRUST: Trusting relations between systems</i>	<i>28</i>

SAP Security Baseline Template

TRUST-A: Trusting relations and trusted destinations – ABAP	28
SSO: Single Sign-On	28
SSO-A: Single Sign-On – ABAP	29
SSO-J: Single Sign-On – Java.....	29
IDPROV: Identity Provider	29
IDPROV-P: Identity Provider – BTP.....	29
2.3.3 Roles and Authorizations.....	30
CRITAU: Critical Authorizations	30
CRITAU-A: Critical Authorizations – ABAP.....	30
CRITAU-J: Critical Authorizations – Java	31
CRITAU-H: Critical Authorizations – HANA	31
CRITAU-P: Critical Authorizations – BTP	31
AUTHASSIGN: Assignment of Authorizations.....	31
AUTHASSIGN-A: Assignment of Authorizations – ABAP	31
AUTHASSIGN-P: Assignment of Authorizations – BTP.....	32
2.3.4 Custom Code Security	32
2.4 Process	32
2.4.1 Regulatory Process Compliance	32
2.4.2 Data Privacy and Protection	32
SECSTO: Protection of Secure Store.....	32
SECSTO-A: Protection of Secure Store – ABAP	32
SECSTO-J: Protection of Secure Store – Java.....	32
2.4.3 Audit and Fraud Management	32
AUDIT: Audit Settings	32
AUDIT-A: Audit Settings – ABAP	32
AUDIT-J: Audit Settings – Java	33
AUDIT-H: Audit Settings – HANA	33
AUDIT-P: Audit Settings – BTP	35
2.5 Organization	35
2.5.1 Awareness	35
2.5.2 Security Governance.....	36
2.5.3 Risk Management	36
3 Addendum.....	37
3.1 Requirements Details.....	37
3.1.1 Requirements List	37
AUDIT: Audit Settings	37
AUDIT-A: Audit Settings - ABAP.....	37
AUDIT-P: Audit Settings - BTP	37
Related Checks in EWA and SOS	38

SAP Security Baseline Template

AUTHASSIGN: Assignment of Authorizations	38
AUTHASSIGN-A: Assignment of Authorizations – ABAP	39
AUTHASSIGN-P: Assignment of Authorizations – BTP	39
CHANGE: Protect Production System against changes	39
CHANGE-A: Protect Production System against changes – ABAP	39
CRITAU: Critical Authorizations	41
CRITAU-A: Critical Authorizations – ABAP	41
CRITAU-H: Critical Authorizations – HANA	42
CRITAU-P: Critical Authorizations – BTP	42
Related Checks in EWA and SOS	43
CUSTOM: Custom Code Security	44
DISCL: Information Disclosure	44
DISCL-A: Information Disclosure – ABAP	44
DISCL-H: Information Disclosure – HANA	44
DISCL-J: Information Disclosure – Java	45
DISCL-O: Information Disclosure – Web Dispatcher	46
FEATAC: Feature Activation	46
FEATAC-P: Feature Activation – BTP	46
IDPROV: Identity Provider	46
IDPROV-P: Identity Provider – BTP	46
MSGSRV: Message Server Security	46
MSGSRV-A: Message Server Security (part of application server ABAP or Java or stand-alone)	47
MSGSRV-J: Message Server Security (part of application server ABAP or Java or stand-alone)	47
Related Checks in EWA and SOS	47
NETCF: Secure Network Configuration	47
NETCF-A: Secure Network Configuration – ABAP	47
NETCF-P: Secure Network Configuration - BTP	47
NETENC: Encryption of Network Connections	47
NETENC-A: Encryption of Network Connections – ABAP	47
NETENC-O: Encryption of Network Connections – Other Components	49
Related Checks in EWA and SOS	49
NOTEST: No Testing Functionality in Production	49
NOTEST-J: No Testing Functionality in Production – Java	49
OBSCNT: Obsolete Clients	49
OBSCNT-A: Obsolete Clients in ABAP	49
OBSCNT-H: Obsolete Tenants in HANA	49
PWDPOL: Password Policy	49
PWDPOL-A: Password Policy – SAP AS ABAP settings.....	50
PWDPOL-H: Password Policy – SAP HANA settings.....	52
PWDPOL-J: Password Policy – SAP AS Java settings (UME)	52

SAP Security Baseline Template

Related Checks in EWA and SOS	52
RFCGW: RFC Gateway Security	52
RFCGW-A: RFC Gateway Security (part of application server ABAP)	53
RFCGW-J: RFC Gateway Security (part of application server Java)	53
RFCGW-O: RFC Gateway Security (stand-alone)	53
Related Checks in EWA and SOS	53
SCRIPT: Scripting Protection	53
SCRIPT-A: Scripting Protection – ABAP	53
SECSTO: Protection of Secure Store	53
SECSTO-A: Protection of Secure Store – ABAP	53
SECSTO-J: Protection of Secure Store – Java	54
SECUPD: Regular Security Updates	54
SECUPD-P: Regular Security Updates – BTP	54
SESS: Session Protection	55
SESS-J: Session Protection – Java	55
SELFRG: No Self-Registration of Users	55
SELFRG-J: No Self-Registration of Users	55
STDUSR: Standard User	55
STDUSR-A: Standard User in ABAP	55
STDUSR-H: Standard Users in HANA	55
Related Checks in EWA and SOS	56
TRACES: Critical Data in trace files	57
TRACES-H: Critical Data in trace files – HANA	57
TRUST: Trusting relations between systems	57
TRUST-A: Trusting relations and trusted destinations – ABAP	57
USRCHAR: Allowed character sets for user names	57
USRCHAR-A: Allowed character sets for user names – ABAP	57
USRCTR: User Control of Action	57
USRCTR-A: User Control of Action – ABAP	57
USRCTR-O: User Control of Action – Others	58
USRTYP: Types of Users	59
USRTYP-P: Types of Users in BTP	59
3.2 Configuration Stores in SAP Solution Manager	60
3.2.1 Configuration Stores ABAP	60
3.2.2 Configuration Stores Java	62
3.2.3 Configuration Stores HANA	63
3.2.4 Configuration Stores Others	63
3.2.5 Configuration Stores for Security Notes	64
3.3 Security Scenario of Focus Insight	64

SAP Security Baseline Template

3.4	Policies for Configuration and Security Analytics (CSA) in SAP Focused Run	
(FRUN)	65	
3.5	Secure by Default settings in S/4HANA and BW/4HANA.....	65
3.5.1	New secure default settings in S/4HANA 2023 and BW/4HANA 2023.....	66
3.5.2	New secure default settings in S/4HANA 2022 and BW/4HANA 2022.....	66
3.5.3	New secure default settings in S/4HANA 2021 and BW/4HANA 2021.....	67
3.5.4	New secure default settings in S/4HANA 2020.....	67
3.5.5	New secure default settings in S/4HANA 1909.....	68
3.6	Security Parameters & Hardening requirements in SAP Enterprise Cloud Services	
(ECS)	69	
3.6.1	New/updated secure default settings in ECS Note 3250501.....	69
3.7	Recommended Security Configurations for SAP Cloud Services	70
4	Appendix: SAP Secure Operations Map.....	73
4.1	Environment	73
4.1.1	Network Security	73
4.1.2	Operating System & Database Security	73
4.1.3	Client Security	73
4.2	System	74
4.2.1	Security Hardening.....	74
4.2.2	Secure SAP Code	74
4.2.3	Security Monitoring & Forensics	74
4.3	Application.....	74
4.3.1	User & Identity Management	74
4.3.2	Authentication and Single Sign-On.....	75
4.3.3	Roles & Authorizations	75
4.3.4	Custom Code Security	75
4.4	Process	75
4.4.1	Regulatory Process Compliance	75
4.4.2	Data Privacy & Protection.....	75
4.4.3	Audit & Fraud Management.....	76
4.5	Organization	76
4.5.1	Awareness	76
4.5.2	Security Governance.....	76
4.5.3	Risk Management	76
5	Appendix: References + Links whitepapers / best practices	77
6	Index	86

SAP Security Baseline Template

1 Overview, Requirements and Guidelines

1.1 Purpose of this template

This template is provided to all interested parties as a sample, how a Security Baseline for SAP systems could look like for a specific company or organization.

Please review it and adapt it to your needs to transform this template to a specific Security Baseline for your environment and requirements!

The idea of a “Security Baseline” is to define all security measures, which are decided to be “basic” in the sense that all related systems should cover them without any further alignment or risk analysis. One should no longer think or discuss about them – just apply them! Then, per system there may be the consideration whether a higher security level is required. For such systems, an additional risk analysis can be conducted, and additional security measures applied. However, such specific additional handling of selected systems is outside the scope of this document.

All proposed regulations in chapter 2 are best-practice-based recommendations, but none of them are carved in stone. Feel free to modify, add or remove any requirement as you consider appropriate for your needs. Important is, that you take informed decisions and that you are aware about the remaining risk and the security level, which you achieve with your specific Security Baseline.

Especially the suggested regulations in chapter 2 marked as [\[Extended\]](#) (see description at the beginning of chapter 2) require your review. They go beyond the [\[Critical\]](#) and [\[Standard\]](#) requirements and either extend the security standards to a higher level of protection or to additional areas. They may not fit to all environments and have to be aligned with your internal policies and organization, your overall IT landscape, your security needs and your current security maturity.

It is definitely better to start with a solid but limited set of the most important requirements and raise the security level over time instead of failing in an attempt to achieve all at once. A good approach is, to initially start with the [\[Critical\]](#) and [\[Standard\]](#) requirements only. Later, the security level can then be increased step by step by reviewing and adding more requirements from the list of [\[Extended\]](#) recommendations included below.

Most important: Transparency and simplicity are key for successful implementation of security. Thus, go for as many requirements as you need, but as few as possible and especially no more than you feel able to handle for the next cycle for security. Security is not a one-time approach – it is a continuous process!

Additional tool support as e.g., provided via the Security Baseline Template package can help you to increase transparency and thus to address a higher level of security whilst maintaining a good overview and sufficient level of simplicity at the same time.

1.2 Structure

This document is structured into the following chapters:

Chapter 1: Overview, Requirements and Guidelines

This chapter provides an overview of the purpose and the structure of this document.

Chapter 2: Regulations

This chapter contains the requirements which have to be fulfilled by all systems governed by this Security Baseline. It is kept as crisp as possible and limited to just name the requirements without any further details or explanation. The idea behind this is to keep the list of all requirements as short as possible to ease handling.

SAP Security Baseline Template

Additional information on requirements is provided in chapter 3. So, if a requirement is clear without any further questions, picking it up from this chapter 2 is completely sufficient. If more information is desired, this might be found in chapter 3.

Chapter 2 is structured according to the following 4 levels:

1. Level: Layer of the Secure Operations Map
2. Level: Topic Area of the Secure Operations Map
3. Level: Requirement
4. Level: Technology

Chapter 3: Addendum

This chapter contains additional information for requirements in chapter 2. It is structured in alphabetical order of the requirement identifiers to ease lookup. However, not all requirements may be covered excluding those requirements for which currently no additional information is provided.

None of the information contained in this chapter may be considered as a requirement which needs to be covered. If anything in this chapter shall become a requirement it must be moved to chapter 2 so that chapter 2 remains the only and complete list of requirements.

Chapter 4: Appendix: SAP Secure Operations Map

As the main structure for the requirements in chapter 2 is the SAP Secure Operations Map, this chapter 4 contains an overview on the different layers and topic areas within the SAP Secure Operations Map for information purposes.

Chapter 5 Appendix: References + Links whitepapers / best practices

Chapter 5 contains many links to helpful further information.

Chapter 6: Index

Finally, chapter 6 closes this document by providing an index for quickly finding requirements and information on specific topics or SAP Notes.

1.3 Support

If you have questions about the Security Baseline Template, please use component XX-SER-SECCHK.

SAP Security Baseline Template

2 Regulations

This section contains the standards and regulations that are mandatory for all SAP systems.¹ The content of this chapter is restricted to focus on the requirements. Additional information on the different requirements can be found in the “Addendum” in the “Requirements Details” chapter.

Each requirement in this chapter is marked with a unique identifier. This identifier is structured as follows:

<Requirement identifier>-<Technology> with

- <Requirement identifier ... > being a unique mnemonic identifier of the requirement
- <Technology> being selected from
 - “A” SAP [A]BAP Application Server
 - “J” SAP [J]ava Application Server
 - “H” SAP [H]ana
 - “O” [O]ther, like Web Dispatcher or SAPGUI
 - “P” BTP [P]latform

In addition, each requirement is marked as either **[Critical]**, **[Standard]** or **[Extended]**.

- **[Critical]** requirements are recommended to be included and addressed with priority, since they relate to well-known especially critical security configurations or needs. They are aligned with the selected set of security checks in the SAP EarlyWatch Alert Security chapter and with those checks in the Security Optimization Service (SOS), which lead to an overall red rating of an SOS report.
- **[Standard]** requirements are typical requirements that should be covered for all SAP systems.
- **[Extended]** requirements go beyond the “Standard” requirements. They either extend the security standards to higher level of protection or to additional areas. When transforming the SAP Security Baseline template into an effective Security Baseline for a specific organization or area, these requirements should be carefully reviewed and evaluated for inclusion. There should be an explicit decision, which of these requirements shall be selected for the specific Security Baseline in focus. Typically, only a subset of them will be included.

¹ Please note: The “mandatory” in this sentence is suggested for inclusion in the final organization-specific baseline document. The SAP Security Baseline Template is not mandatory in any aspect.

SAP Security Baseline Template

2.1 Environment

In the Secure Operations Map, the “Infrastructure Security” layer is about requirements from SAP systems and solutions to their environment. This version of the SAP Security Baseline Template focuses on requirements towards the SAP solutions themselves. Thus, this chapter for “Infrastructure Security” is without content for now. In a later version of the SAP Security Baseline Template, it may get filled with requirements towards the non-SAP environment.

2.1.1 Network Security

Currently there are no specific regulations in this chapter.

2.1.2 Operating System and Database Security

USRCTR: User Control of Action – Others

USRCTR-O: User Control of Action – Others

a) Permissions of OS user on Windows

[Critical]

If an SAP system is installed on Windows, several users are created on operating system level:

- The user <sid>adm is used for administrative purposes on operating system level. It is member of the local Administrators group.
- The user SAPService<SID> is the account to run the SAP system. It must not be a member of the local Administrators group.
- The user sapadm is the account to run the SAP Host Agent. It must not be a member of the local Administrators group.
- Further users depending on the version of the installation.

Hint: When SAP Host Agent is upgraded to the latest version, the settings for sapadm are automatically corrected to be compliant.

SAP System Security on Windows - SAP Help Portal

b) Permissions of OS users on Unix/Linux

[Critical]

If an SAP system is installed on Unix/Linux the account <sid>adm is used to run the SAP system. The account <sid>adm must not have root permissions.

The account sapadm is used to run the SAP Host Agent. The account sapadm must not have root permissions. The default shell /bin/false as defined in /etc/passwd of the account sapadm must not be changed.

Hint: When SAP Host Agent is upgraded to the latest version, the settings for sapadm are automatically corrected to be compliant.

SAP System Security Under UNIX/LINUX - SAP Help Portal

c) Secure shares / exports

[Standard]

Shares / NFS exports must not be accessible by everyone / all domain users. Shares / NFS exports must only be accessible from dedicated systems and/or with dedicated accounts.

Shares used by the SAP System (e.g. saploc, sapmnt) must only be accessible for SAP system users and dedicated admin accounts (e.g. <sid>adm).

SAP Security Baseline Template

File permissions for `/usr/sap` must be only granted to SAP admins and SAP technical users (e.g. `<sid>adm`).

2.1.3 Client Security

Currently there are no specific regulations in this chapter.

2.2 System

2.2.1 Security Hardening

CHANGE: Protect Production System against changes

CHANGE-A: Protect Production System against changes – ABAP

- a) System Change Option “Global Settings” should be set to “Not modifiable” (Transaction `SE06`). You can check the setting in transaction `SE16` for table `TADIR`, too: Select the entry for `PGMID = HEAD` and `OBJECT = SYST` and check whether `EDTFLAG = N` or `P`. [Critical]
- b) Client Change Option: Use transaction `SCC4` to define following settings for all production clients:
 - “Client role” = “Live” (for client 000, you can use setting “SAP reference” as well)
 - “Changes and Transports for Client-Specific Objects” = “No changes allowed”
 - “Cross-Client Object Changes” = “No Changes to Repository and Cross-Client Customizing Objects”
 - “Client Copy and Comparison Tool Protection” is set either to “Protection level1: No overwriting” or to “Protection level2: No overwriting, no external availability”.

You can check the settings in transaction `SE16` for table `T000` for all clients, whether `CCCORACTIV = 2` and `CCNOCLIIND = 3` and `CCCOPYLOCK = X` or `L`. `CCCATEGORY = P` means production client. [Critical]
- c) Activate profile parameter to create customizing table logs
Profile parameter `rec/client` `<> OFF`, recommended value `ALL` (see note [1916](#)) [Standard]
- d) Activate transport parameter to create customizing table logs as part of transports
Transport parameter `RECCLIENT` is defined and not set to `OFF` [Extended]
- e) Activate transport parameters to create versions of repository objects as part of transports
Transport parameter `VERS_AT_EXP`. Use `NO_T` respective `TRUE`, `YES`, `ON`, or `1` for development systems (see note [2296271](#)).
Transport parameter `VERS_AT_IMP`. Decide if value `ALWAYS` should be used for production systems (see note [1784800](#)). [Extended]
- f) Activate transport parameter to validate the content of transport files
Transport parameter `TLOGOCHECK = TRUE` (You can use another accepted secure value like `YES`, `ON`, or `1` as well) [Standard]
- g) Use at least a specific version of `tp/R3trans`
Validate the Kernel release or the transport parameters `TP_RELEASE >= 380.44.90` respective `TP_VERSION >= 380` See note [2671160](#) [Extended]
- h) Set profile parameter `abap/ext_debugging_possible = 2` [Standard]
- i) Set profile parameter `dba/dba/ccms_maintenance = 1` to prevent unauthorized access and maintenance actions in DBA Cockpit. [Standard]

SAP Security Baseline Template

- j) Set profile parameter `dba/ccms_security_level = 1` to allow only authorized users with the required roles to execute CCMS DBA functions. [Standard]

DISCL: Information Disclosure

Disclosure of unnecessary information about versions or from errors must be prohibited.

DISCL-A: Information Disclosure – ABAP

- a) Set profile parameter `login/show_detailed_errors = 0` (see note [2001962](#)) [Standard]
- b) The rules from chapter DISCL-O: Information Disclosure – Web Dispatcher are relevant for ABAP based systems as well to cover the requirements of the Internet Communication Manager (ICM). [Standard]
- c) Web methods of `sapstartsrv` must be protected by setting profile parameter `service/protectedwebmethods` to SDEFAULT (or ALL) with a limited list of exceptions. [Standard]

DISCL-H: Information Disclosure – HANA

- a) Enable HANA data at rest encryption. [Extended]
- b) Protect the keys for HANA data at rest encryption. [Extended]

DISCL-J: Information Disclosure – Java

- a) Server Header must be disabled by setting property `UseServerHeader` to `false` in the HTTP Provider Service in the global configuration of dispatcher and server nodes. [Standard]
- b) Web methods must be protected by setting profile parameter `service/protectedwebmethods` to SDEFAULT (or ALL) with a limited list of exceptions. [Standard]

DISCL-O: Information Disclosure – Web Dispatcher

- a) Information disclosure for Web Dispatcher and Internet Communication Manager (ICM) must be prohibited by setting profile parameters according following rules:
- `is/HTTP/show_server_header= false, FALSE or 0`
- `is/HTTP/show_detailed_errors = false, FALSE or 0`
- `icm/SMTP/show_server_header <> true, TRUE or 1` (which is already the Kernel default) [Standard]
- b) The following Web Dispatcher URL filter entries shall be included into a file which you address via profile parameter `wdisp/permission_table` (which therefore should not be empty):
- `D /sap/public/icman/*`
- `D /sap/public/ping`
- `D /sap/public/icf_info/*`
- `D /sap/wdisp/info` [Standard]

As of SAP NetWeaver 7.50 This configuration via this profile parameter is obsolete and should no longer be used. Instead, use specific settings (which extend the default value) for the authorization handler: Profile parameter `icm/HTTP/auth_<xx>`.

SAP Security Baseline Template

- c) Profile parameter `icm/HTTP/admin_<num>` should contain sub-parameters `CLIENTHOST` (any value) to restrict administrative access to specific clients and `ALLOWPUB=FALSE` to require authentication for certain administration pages (see note [2260323](#)). [Standard]
- d) Profile parameter `icm/HTTP/error_tmpl_path` should contain `/usr/sap/<SID>/<Instance>/data/icmerror` (see notes [1616535](#) respective [2260323](#)). [Standard]
- e) Profile parameter `rdisp/TRACE_HIDE_SEC_DATA` should be activated (see note [2012562](#)). Valid values are `on`, `ON` [Standard]
- f) Profile parameter `icm/trace_secured_data` should not be activated (see note [634262](#)). Valid values are `false`, `FALSE` or `0`. [Standard]
- g) Profile parameter `icm/accept_forwarded_cert_via_http` should not be activated (see note [2656696](#)). Valid values are `false`, `FALSE` or `0`. [Standard]
- h) Profile parameter `icm/trusted_reverse_proxy_<num>` should either not be set or should not contain wildcards for `SUBJECT` or `ISSUER` (see note [2052899](#)). [Standard]

FILE: Directory Traversal Protection

Protect the file system against possible attacks via applications. [Out of scope: protection of the file system on operating system level.]

FILE-A: Directory Traversal Protection – ABAP

- a) Profile parameter `abap/path_normalization <> off` should not be deactivated (see notes [1497003](#), [2551541](#), [2562089](#)).
On Windows-based system, the profile parameter `abap/path_norm_Windows` with default value `0` should not be changed (respective on Kernel 722 should be set to value `0`), see note [2634476](#) [Standard]
- b) Control critical authorization for authorization object `S_PATH` based on customizing table `SPTH`. [Extended]
- c) Control critical authorization for authorization object `S_DATASET`. [Extended]
- d) The parameter `REJECT_EMPTY_PATH` should either not be set in transaction `SFILE` respective table `FILECMCUSTP` according to notes [2251231](#) and [2395138](#) or should have its default value `ON`. Use the Security Audit Log events `CUQ`, `CUR`, `CUS`, `CUT`, `DU5` and `EU4` to log events related to file access. [Extended]
- e) The parameter `UNCONF_PATH_AS_EMPTY` should not be set in transaction `SFILE` respective table `FILECMCUSTP` according to note [3286256](#) (and it should not have a different value than the default value `ON`) [Standard]

MSGSRV: Message Server Security

The Message Server must be configured to protect application server communication within a system and to control monitoring and administration access. You find installations of a Message Server on ABAP systems as well as on Java Systems.

MSGSRV-A: Message Server Security

- a) The Message Server ports must be split into an internal port (for communication with the application servers) and an external port (for communication with clients / users).
The Message Server internal port can be defined via profile parameter

SAP Security Baseline Template

rdisp/msserv_internal. This port must be blocked by all firewalls between the server network and the client network so that no client can connect to this internal Message Server port. (Kernel default 9311 as of kernel 7.81.)

[Standard]

- b) External monitoring of the Message Server must be prohibited by setting profile parameter `ms/monitor = 0`

[Standard]

- c) External administration of the Message Server must be either not set or deactivated by setting profile parameter `ms/admin_port = 0`

[Standard]

- d) The Access Control List of the Message Server must be maintained via profile parameter `ms/acl_info` and should point to a secured directory

(This requirement is less critical for ABAP systems if profile parameter `system/secure_communication = ON` according to requirement [NETENC-A](#))

[Extended] / [Critical]

- e) The Access Control List of the Message Server should not contain dummy entries like `HOST=*` (This requirement is less critical for ABAP systems if profile parameter `system/secure_communication = ON` according to requirement [NETENC-A](#))

[Extended] / [Critical]

- f) Do not allow unauthenticated monitoring of a Message Server from the Browser via profile parameter `ms/server_port_<xx>`.

Do not set this parameter in RZ10.

Do not set the profile parameter temporarily in transaction RZ11 and do not change the current setting in transaction SMMS. If you are using this parameter, then use the sub-parameter `ACLFILE`, too (see KBA [3272585](#)).

Check change documents for profile parameter changes regularly in transaction RZ11 or using transaction SM21 (for messages Q19 and Q1A) or report `ZRSPFPAR_DYNAMIC_CD` (from [Github](#)).

[Critical]

MSGSRV-J: Message Server Security

The rules from MSGSRV-A apply for Java systems as well.

NETCF: Secure Network Configuration

NETCF-A: Secure Network Configuration – ABAP Profile parameter

`auth/rfc_authority_check` must be set to 1 or 6 or 9 to activate the RFC authorization checks. (see note [2216306](#))

[Standard]

- b) Profile parameter `rfc/callback_security_method = 3` to block unauthorized remote callbacks. (see note [2678501](#))

[Standard]

- c) Profile parameter `rfc/selftrust = 0` (see notes [2449757](#), [2614667](#))

[Standard]

- d) The following ICF services must be disabled if existing in the actual release (* and are not used in business scenarios, ** respective might require an exemption):

`/sap/bc/bsp/sap/bsp_veri`

Note [1422273](#)

`/sap/bc/bsp/sap/certmap`

*Note [1417568](#)

`/sap/bc/gui/sap/its/CERTMAP`

Note [1417568](#)

`/sap/bc/bsp/sap/certreq`

* Note [1417568](#)

`/sap/bc/gui/sap/its/CERTREQ`

Note [1417568](#)

`/sap/bc/echo`

Note [626073](#)

`/sap/bc/error`

Note [626073](#)

SAP Security Baseline Template

/sap/bc/FormToRfc	Note 626073
/sap/bc/bsp/sap/icf	Note 1422273
/sap/bc/srt/IDoc	** Note 1487606
/sap/bc/idoc_xml	Note 1487606
/sap/bc/report	Note 626073
/sap/bc/soap/rfc	Note 1394100
/sap/bc/webrfc	Note 979467
/sap/bc/xrfc	Note 626073
/sap/bc/xrfc_test	Note 626073

Critical services according to note [887164](#):

/sap/bc/bsp/sap/bsp_model	
/sap/bc/bsp/sap/htmlb_samples	
/sap/bc/bsp/sap/it00	
/sap/bc/bsp/sap/it01	
/sap/bc/bsp/sap/it02	
/sap/bc/bsp/sap/it03	
/sap/bc/bsp/sap/it04	
/sap/bc/bsp/sap/it05	
/sap/bc/bsp/sap/itmvc2	
/sap/bc/bsp/sap/itsm	
/sap/bc/bsp/sap/sbspext_htmlb	
/sap/bc/bsp/sap/sbspext_phtmlb	
/sap/bc/bsp/sap/sbspext_table	Note 2948239
/sap/bc/bsp/sap/sbspext_xhtmlb	
/sap/bc/bsp/sap/system_private	
/sap/bc/bsp/sap/system_public	

[Standard]

- e) Profile parameter `ixml/dtd_restriction = expansion` or prohibited (see notes [2308217](#), [1712860](#)) [Standard]
- f) Profile parameter `login/disable_cplic = 1` (see note [2926224](#)) [Standard]
- g) Profile parameter `wdisp/add_xforwardedfor_header = TRUE` (see note [2788140](#)) [Standard]
- h) Activated UCON HTTP allow list for 01 Trusted Net- work Zone and 03 CSS Style Sheet to accept e.g. only an relative path; activate 02 Clickjacking Framing Protection [Standard]

NETCF-H: Secure Network Configuration HANA

- a) SAP HANA network settings for internal services must be configured according to SAP Note [2183363](#).

For single host systems, the parameter `listeninterface` in section `communication` of file `global.ini` must be set to `.local` to enforce that the HANA internal communication listens to the HANA internal loop back interface only.

For distributed systems, a separate network must be configured for internal communication. The parameter `listeninterface` must be set to `.internal` and the section `internal_hostname_resolution` must be maintained accordingly. [Critical]

NETCF-P: Secure Network Configuration – BTP

- a) Cloud Connector(s) connected to the subaccount should be operated in high availability mode. [Standard]

SAP Security Baseline Template

NOTEST: No Testing Functionality in Production

Functionality for development or testing purposes which are not intended for production must not be available in production.

Following requirements, which are defined in other chapters, match to topic *NOTEST*, too:

- Deactivation of test services in `SICF`, see *NETCF-A d*)
- No authorizations for unit testing of functions `S_DEVELOP_FUGR 16`, see *CRITAU-A c) 7*.
- No authorizations for unit testing of methods `S_DEVELOP_CLASS 16`, see *CRITAU-A c) 8*.

NOTEST-J: No Testing Functionality in Production – Java

- a) The Invoker Servlet must be disabled by setting property `EnableInvokerServletGlobally` to `false` in the `servlet_jsp` service in the global configuration of server nodes. **[Critical]**

OBSCNT: Obsolete Clients/Tenants

Obsolete Clients (in ABAP) or Tenants (in HANA) must be removed

OBSCNT-A: Obsolete Clients in ABAP

- a) Obsolete clients in ABAP must be deleted.
This is especially true for clients `066` (always) and `001` (if not in use). **[Standard]**

OBSCNT-H: Obsolete Tenants in HANA

- a) Obsolete Tenants in HANA should be deleted. **[Extended]**

SCRIPT: Scripting Protection

Protect the application against possible attacks via scripting.

SCRIPT-A: Scripting Protection – ABAP

- a) The general recommendation is to disable scripting completely (`sapgui/user_scripting = FALSE`) as it's a potential security risk.

However, in some case you want to or have to use scripting. In this case you should activate scripting only for these users who need it (`sapgui/user_scripting = TRUE` and `sapgui/user_scripting_per_user = TRUE` and a role assignment for a role containing authorization object `S_SCR` with activity `16`). See notes [2296251](#) and [2565390](#).

Profile Parameter `sapgui/nwbc_scripting = FALSE`

Profile Parameter `sapgui/user_scripting = FALSE`

Profile Parameter `sapgui/user_scripting_per_user = TRUE`

Profile Parameter `sapgui/user_scripting_disable_recording = TRUE`

If this parameter is set to `TRUE`, script playback is possible, but recording is not permitted. Profile Parameter `sapgui/user_scripting_set_readonly = TRUE` If this parameter is set to `TRUE`, scripts may only act on read-only user interface elements.

This parameter has a different behavior when combined with profile parameter `sapgui/user_scripting_per_user`, see note [2565390](#).

Profile Parameter `sapgui/user_scripting_force_notification = TRUE`

If this parameter is set to `TRUE`, a notification is always displayed at the frontend, regardless of the client options described below under 'Warning Options on Client Side'. **[Extended]**

SAP Security Baseline Template

SESS: Session Protection

Protect web-based sessions against known attacks

SESS-J: Session Protection – Java

- a) The `HttpOnly` attribute shall be enabled for system cookies by having the HTTP service property `SystemCookiesDataProtection` set to `true`. (see note [2068872](#)) [Standard]
- b) The transmission of web session tracking and load balancing cookies shall be restricted via the cookies' "Secure" attribute to HTTPS-secured connections only by having the Web Container property `SystemCookiesHTTPSProtection` set to `true`. (only to be applied for connections, which are secured via HTTPS). (see note [2068872](#)) [Standard]

TRACES: Critical Data in trace files

In normal operations, traces must be restricted to a level, on which critical data are not written into trace files.

TRACES-H: Critical Data in trace files – HANA

- a) The SQL trace level must not be set to `ALL_WITH_RESULTS` in file `indexserver.ini` section `sqltrace` parameter `level` [Critical]

USRCTR: User Control of Action

USRCTR-A: User Control of Action – ABAP

- a) The user must be able to properly see and control any action triggered by him.
Set either profile parameter `dynp/checkskip1screen = ALL` (see notes [2999707](#), [1399324](#) and [1157137](#)) or profile parameter `dynp/confirmskip1screen = ALL` (see note [1956086](#)) but not both.
See "How to prefill fields and skip first screen with webgui?" at https://help.sap.com/docs/SUPPORT_CONTENT/uiwits/3361892781.html [Standard]
- b) Profile parameter `auth/check/calltransaction = 2` or `3` (recommended) (see note [515130](#)) [Standard]
- c) Profile parameter `auth/no_check_in_some_cases = Y` (see note [1723881](#)) [Standard]
- d) Profile parameter `auth/object_disabling_active = N` (see note [2926224](#)) [Standard]
- e) Profile parameter `rdisp/gui_auto_logout` less or equal 3600 sec (1 hour) [Standard]
- f) Profile parameter `rdisp/vbdelete >= 400`. [Standard]
- g) Most² Switchable authorization check framework (SACF) scenarios should be active in transaction `SACF_COMPARE`. Make sure that users have appropriate authorizations. [Standard]
- h) All Generic Application Access Rules (SLDW) scenarios should be active in transaction `SLDW_COMPARE`. [Extended]

² Following SACF scenarios are not activated by Secure-by-Default in S/4HANA according to the exception list in function `SACF_SET_SBD`:

`BC_GENERIC_REPORT_START`, `BC_GENERIC_REPORT_START_BATCH`,
`SACF_DEMO_SCENARIO`, `FIN_PARL_ACCTG_LEDGER`.

SAP Security Baseline Template

- i) Authorization object S_START should be activated to secure access to WebDynpro ABAP applications in transaction SU25 (if available depending on the release), see notes [1413011](#) and [3064888](#). [Standard]
- j) Profile parameter rfc/authCheckInPlayback = 1 (see note [3600840](#)) [Standard]

2.2.2 Secure SAP Code

SECUPD: Regular Security Updates

SAP Software on premise has to be updated regularly to the latest version or Support Package Stack at least once a year. A Security Patch Process with clearly defined roles and responsibilities should be defined.

SECUPD-A: Regular Security Updates – ABAP

- a) The SAP software of an ABAP system must be updated at least once a year to the latest available versions. This covers the ABAP software components like SAP_BASIS and the Kernel including the CommonCryptoLib [Critical]
- b) SAP Security Notes must be reviewed timely and implemented timely – if not decided and documented otherwise in the review. [Critical]

SECUPD-J: Regular Security Updates – Java

- a) The components of a Java system must be updated at least once a year to the latest versions. This covers the JAVA software components like J2EECORE and the Kernel including the CommonCryptoLib. [Critical]
- b) SAP Security Notes must be reviewed timely and implemented timely – if not decided and documented otherwise in the review. [Critical]

SECUPD-H: Regular Security Updates – HANA

- a) The revision of an SAP HANA must be updated at least once a year to the latest revision. [Critical]
- b) SAP Security Notes must be reviewed timely and implemented timely – if not decided and documented otherwise in the review. [Critical]

SECUPD-O: Regular Security Updates – SAPGUI

- a) The client installations, like SAPGUI or the client part of the Business Client, on all client computers must be updated at least once a year to the latest version. [Critical]
- b) SAP Security Notes must be reviewed timely and implemented timely – if not decided and documented otherwise in the review. [Critical]

SECUPD-P: Regular Security Updates – BTP

- a) Cloud Connector(s) connected to the subaccount should have the most current version installed. [Standard]

FEATAC: Feature Activation

FEATAC-P: Feature Activation – BTP

- a) Beta features should not be enabled for productive subaccounts. [Standard]

SAP Security Baseline Template

2.2.3 Security Monitoring and Forensics

Currently there are no specific regulations in this chapter.

2.3 Application

2.3.1 User and Identity Management

SELFREG: No Self-Registration of Users

Self-registration capabilities for user must be switched of.

SELFREG-J: No Self-Registration of Users

a) Do not activate self-registration for users in the UME

[Standard]

STDUSR: Standard Users

Standard user accounts must be properly handled for the security of the corresponding system. Default passwords must be changed. The usage of standard users should be restricted to the required needs.

STDUSR-A: Standard Users in ABAP

a) User `SAP*`: During normal operations you use a different user as an emergency user. Therefore, following rules apply for user `SAP*`.

[Critical]

- The user must exist in all clients.
- The user must be locked in all clients.
- The password must be changed from the default value.
- The user must belong to the group `SUPER` in all clients.
- No profile should be assigned, especially not the authorization profile `SAP_ALL`.
- The profile parameter `login/no_automatic_user_sapstar` must be set to 1.
- You have a well-defined process description concerning the virtual user `SAP*` which you can create as described in note [3303172](#).
- You log all events for this user in the Security Audit Log, including event `EUP`.

b) User `DDIC`:

[Critical]

- The password must be changed from the default value.
- The user must belong to the group `SUPER` in all clients.

c) User `SAPCPIC`:

[Critical]

- If you don't need this user, then this user should be deleted.
- The password must be changed from the default value.
- The user must belong to the group `SUPER` in all clients.

d) User `TMSADM`:

[Critical]

- The password must be changed from the default value.
- The user must not exist in any other client than client `000`.
- The user must belong to the group `SUPER`.

SAP Security Baseline Template

- Only authorization profile `S_A.TMSADM` should be assigned to user `TMSADM`.
- Consider changing the default password using the process described in note [1414256](#).

e) User `EARLYWATCH`:

[Critical]

This user should not exist in any client.

Regarding its use in client `066` see requirement `OBSCNT-A`.

f) Standard users created by the SAP Solution Manager

Potential default passwords for users `SOLMAN_BTC`, `CONTENTSERV`, `SMD_BI_RFC`, `SMD_RFC`, `SMDAGENT_<SAPSolutionManagerSID>`, `SMD_ADMIN`, `SMD_AGT`, `SAPSUPPORT` and `SOLMAN_ADMIN` must be changed.

[Standard]

STDUSR-H: Standard Users in HANA

a) Deactivate the user `SYSTEM`. Do not restrict the valid time range of user `SYSTEM`.

(Caveat: You must have set up an administration concept and corresponding administrators before doing this!)

[Standard]

USRTYP: Types of Users

All users should be part of the customers' user base and no external user should have access to productive environments. Users should have it's correct user type, i.e. you should differentiate between personal users and technical users.

USRTYP-A: User types of reference users in ABAP

- a) Only users of user type "Reference" (L) should be assigned to other users as reference users. The corresponding setting in customizing table `PRGN_CUST` should prohibit any other assignments: `REF_USER_CHECK = E`

[Standard]

USRTYP-P: Types of Users in BTP

BTP distinguishes between two different types of users: platform users and business users. They correspond to a particular user in an identity provider, such as the default identity provider (SAP ID Service) or a custom identity provider.

The users from the SAP ID Service are categorized in the following user classes:

- P-user (public users) which can registered by persons themself
- S-user (SAP Support Portal Users)
- I- and D-users (internal SAP employees)
- C-users (external SAP employees)

The following requirements apply to platform users of the global account, directories and multi-environment subaccounts only.

- a) The user base for platform users should be provided by the custom identity provider.

[Standard]

- b) No platform user from default identity provider with external email address domain should have viewer privileges.

[Standard]

- c) No platform user from default identity provider with external email address domain should have administrative privileges.

[Critical]

SAP Security Baseline Template

The following requirements apply to platform users (members) of Cloud Foundry organizations and spaces only.

- d) The user base for Cloud Foundry organization and space members should be provided by the custom identity provider. [Standard]
- e) No Cloud Foundry organization or space member from default identity provider with external email address domain should be assigned to one of the following viewer privileges: Org Auditor, Space Auditor [Standard]
- f) No Cloud Foundry organization or space member from default identity provider with external email address domain should be assigned to one of the following administrative privileges: Org Manager, Space Developer, Space Manager [Critical]

The following requirements apply to platform users of Neo environment subaccounts only.

- g) The user base for platform users should be provided by the custom identity provider. [Standard]
- h) No platform user from default identity provider should belong to the user classes C-, D- or I-user. [Standard]
- i) No platform user from default identity provider should be a public user (P-user). [Critical]

The following requirements apply to business users of Multi-Environment and Neo environment subaccounts only.

- j) The user base for business users should be provided by the custom identity provider. [Standard]
- k) No business user from default identity provider should belong to the user classes C-, D-, I-, or P- user or has an external email address domain. [Critical]

USRCHAR: Allowed character sets for user names

USRCHAR-A: Allowed character sets for user names in ABAP

- a) Prohibit that user names could contain 'wide' spaces using customizing settings BNAME_RESTRICT = XXX in table PRGN_CUST. This requirement is important for development systems. See note [1731549](https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbcccf/8a922c9d7bca45c9b29bff3c59b344df.html) and https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbcccf/8a922c9d7bca45c9b29bff3c59b344df.html [Standard]

2.3.2 Authentication and Single Sign-On

NETENC: Encryption of Network Connections

All communication across non-trusted networks has to be authenticated and encrypted. Especially, the internal client workstation network has to be considered as "non-trusted" unless sufficient other security mechanisms are in place that make it a trusted network.

NETENC-A: Encryption of Network Connections – ABAP

- a) Profile parameter `snc/enable = 1`
Enable SNC-Module (SNC = Secure Network Communications) [Standard]
- b) Enforce encryption for SNC setting profile parameters
`snc/data_protection/min = 3`

SAP Security Baseline Template

snc/data_protection/max = 3

snc/data_protection/use = 3 or 9

[Standard]

- c) The inbound RFC or GUI connections should be encrypted. Set the profile parameters snc/accept_insecure_gui = U (or 0) and snc/accept_insecure_rfc = U (or 0) to enable that the logon inbound connection is secured with SNC accepting user specific exceptions.
Set the profile parameters snc/only_encrypted_gui = 1 and snc/only_encrypted_rfc = 1 to enforce that the logon inbound connection is secured with SNC. [Extended]
- d) Profile parameter snc/log_unencrypted_rfc = 2 [Extended]
- e) Profile parameter system/secure_communication = ON (see Notes [2040644](#), [2362078](#)) [Critical]
- f) Set profile parameters ssl/ciphersuites according to note [3346659](#) like 1159:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH for existing systems or 1569:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH for new systems (see note [510007](#), too) [Extended]
- g) Set profile parameter ssl/client_ciphersuites according to note [3346659](#) like 1174:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH (see note [510007](#), too) [Extended]
- h) Set profile parameter snc/permit_insecure_start = 0 [Extended]

NETENC-O: Encryption of Network Connections – Web Dispatcher

- a) Use https to protect information communicated via the Web Dispatcher. Define the corresponding port via profile parameter icm/server_port_<num> with value PROT=HTTPS. [Standard]
- b) Allow Web Dispatcher administration only on a port, which is protected by HTTPS by setting the PORT option of the profile parameter icm/HTTP/admin_<num> to an HTTPS port. [Standard]

PWDPOL: Password Policy

General Requirements

- a) Passwords must be at least 12 characters long. Longer passwords must be possible
- b) Initial passwords must be changed after 14 days at the latest.
- c) Passwords for interactive users should be changed after half a year at the latest

PWDPOL-A: Password Policy – ABAP

- a) Profile parameter login/min_password_lng ≥ 12 respective security policy attribute MIN_PASSWORD_LENGTH ≥ 12 [Critical]
- b) Profile parameter login/password_max_idle_initial between 1 to 14 respective security policy attribute MAX_PASSWORD_IDLE_INITIAL between 1 and 14, recommended value 7 (see note [862989](#)) [Critical]
- c) Profile parameter login/password_expiration_time between 1 and 183 respective security policy attribute PASSWORD_CHANGE_INTERVAL between 1 and 183 [Extended]

Additional technology-specific regulations:

SAP Security Baseline Template

- d) Profile parameter `login/password_downwards_compatibility = 0`
No enforcement of password downwards compatibility (8 / 40 characters, case-sensitivity), no old weak password hashes. (see note [1023437](#)) [Critical]
- e) Profile parameter `login/password_compliance_to_current_policy = 1`
respective security policy attribute `PASSWORD_COMPLIANCE_TO_CURRENT_POLICY = 1`
Enforce compliance of password with current password policy. With this configuration, users with incompatible password will be prompted for a password change in the next logon. Users of type "system" and "service" are not affected by this change.
(see note [862989](#)) [Standard]
- f) Redundant old downward compatible password hashes must be removed. Table `USR02` should not contain any values in field `BCODE` and `PASSCODE`.
(see note [1458262](#)) [Standard]
- g) Profile parameter `icf/reject_expired_passwd = 1` (see note [2579165](#)) [Standard]
- h) Profile parameter `rfc/reject_expired_passwd = 1` (see note [1591259](#)) [Standard]
- i) Define rules for additional profile parameters respective security policy attributes about password complexity. Use the following list of parameters to decide about your corporate security policy.
You might decide to ignore some of the entries:
- | | | |
|---|--------------------------------------|---------------------|
| <code>login/min_password_digits</code> | <code>MIN_PASSWORD_DIGITS</code> | <code>>=1</code> |
| <code>login/min_password_letters</code> | <code>MIN_PASSWORD_LETTERS</code> | <code>>=1</code> |
| <code>login/min_password_lowercase</code> | <code>MIN_PASSWORD_LOWERCASE</code> | <code>>=1</code> |
| <code>login/min_password_uppercase</code> | <code>MIN_PASSWORD_UPPERCASE</code> | <code>>=1</code> |
| <code>login/min_password_specials</code> | <code>MIN_PASSWORD_SPECIALS</code> | <code>>=1</code> |
| <code>login/min_password_diff</code> | <code>MIN_PASSWORD_DIFFERENCE</code> | <code>>=3</code> |
- [Extended]
- j) Define rules for additional profile parameters respective security policy attributes about password management:
- | | | |
|---|---|----------------------------------|
| <code>login/disable_password_logon</code> | <code>DISABLE_PASSWORD_LOGON</code> | <code>not empty</code> |
| <code>login/fails_to_user_lock</code> | <code>MAX_FAILED_PASSWORD_LOGON_ATTEMPTS</code> | <code>1-5</code> |
| <code>login/failed_user_auto_unlock</code> | <code>PASSWORD_LOCK_EXPIRATION</code> | <code>=0</code> |
| <code>login/password_max_idle_productive</code> | <code>MAX_PASSWORD_IDLE_PRODUCTIVE</code> | <code>>=1 and <=180</code> |
- recommended value 180, (see note [862989](#))
- | | | |
|---|---|------------------------|
| <code>login/password_change_waittime</code> | <code>MIN_PASSWORD_CHANGE_WAITTIME</code> | <code>not empty</code> |
| <code>login/password_change_for_SSO</code> | <code>PASSWORD_CHANGE_FOR_SSO</code> | <code>=1</code> |
| <code>login/password_history_size</code> | <code>PASSWORD_HISTORY_SIZE</code> | <code>>=5</code> |
- (Out of scope: Table `USR40` and policy attribute `CHECK_PASSWORD_BLACKLIST`) [Extended]
- k) Adjust the rule about the profile parameter describing the password hash algorithm.
Example:
`login/password_hash_algorithm = encoding=RFC2307, algorithm=iSSHA-512, iterations=15000, saltsize=256` (see note [2140269](#)) [Extended]
- l) Define a rule about profile parameter `login/password_logon_usergroup`, especially if the associated parameter is used: `login/disable_password_logon = 1`. [Extended]

SAP Security Baseline Template

- m) Define a rule for additional security policy attributes about ticket logon:
`DISABLE_TICKET_LOGON` is not empty [Extended]

PWDPOL-J: Password Policy – Java

- a) UME property `ume.logon.security_policy.password_min_length ≥ 12`
(Minimum Password Length) [Critical]
- b) UME property `ume.logon.security_policy.password_expire_days ≤ 183` [Extended]

Additional technology-specific regulations:

- c) UME property `ume.logon.security_policy.userid_in_password_allowed = FALSE`
(User ID in password allowed) [Extended]
- d) UME property `ume.logon.security_policy.oldpass_in_newpass_allowed = FALSE`
(Old password in new password allowed) [Extended]
- e) Define rules for additional UME properties
`ume.logon.security_policy.password_alpha_numeric_required`
`ume.logon.security_policy.password_mix_case_required`
`ume.logon.security_policy.password_special_char_required` [Extended]
- f) UME property `ume.logon.security_policy.password_history ≥ 5` [Extended]
- g) UME property `ume.logon.security_policy.password_max_idle_time` between `≥1`
and `≤ 180` [Extended]

PWDPOL-H: Password Policy – HANA

- a) The following password policy parameters in section `password policy` of file `indexserver.ini` must be set:

`minimal_password_length ≥ 12` (minimum password length)
`maximum_unused_initial_password_lifetime ≤ 14` (max. validity of initial passwords) [Critical]
- b) `force_first_password_change = true` or `TRUE` (enforce password change at first logon) [Standard]
- c) The password lifetime defined by password policy parameter `maximum_password_lifetime` must be limited for all users to at most half a year (`≤ 183`).
Exception: Technical users may get an unlimited password lifetime, if required. [Extended]
- d) Password policy parameter `maximum_unused_productive_password_lifetime` between `≥1` and `≤180` [Extended]
- e) Password policy parameter `last_used_passwords ≥ 5` [Extended]
- f) Define a rule about password complexity, e.g. by setting password policy parameter `password_layout = Ala_` [Extended]
- g) Number of Allowed Failed Logon Attempts
The maximum number of failed logon attempts that are permitted; the user is locked as soon as this number is reached.
`maximum_invalid_connect_attempts ≤ 6` [Extended]

SAP Security Baseline Template

- h) Exempt SYSTEM User from Locking
Indicates whether or not the user SYSTEM is locked for the specified lock time (password_lock_time) after the maximum number of failed logon attempts (maximum_invalid_connect_attempts)
password_lock_for_system_user = true (default) [Extended]
- i) User Lock Time
The number of minutes for which a user is locked after the maximum number of failed logon attempts
password_lock_time >= 1440 (one day) [Extended]
- j) Minimum Password Lifetime
The minimum number of days that must elapse before a user can change his or her password
minimum_password_lifetime >= 1 [Extended]
- k) Notification of Password Expiration
The number of days before a password is due to expire that the user receives notification
password_expire_warning_time >= 7 [Extended]

You find the documentation about these parameters here:

https://help.sap.com/docs/SAP_HANA_PLATFORM/b3ee5778bc2e4a089d3299b82ec762a7/61662e3032ad4f8dbdb5063a21a7d706.html

RFCGW: RFC Gateway Security

The RFC Gateway must be configured to restrict access to started and registered RFC servers to an acceptable minimum. You find installations of a RFC Gateway on ABAP systems as well as on Java Systems.

RFCGW-A: RFC Gateway Security (part of application server ABAP)

- a) The RFC Gateway Access Control Lists `secinfo` and `reginfo` must be maintained to restrict access to RFC servers to expected sources. Do not enter a full generic rule which allows everything. [Critical]
- b) The profile parameters `gw/sec_info` and `gw/reg_info` must be set to the filenames of the `secinfo` and `reginfo` access control list files respectively. [Critical]
- c) Profile parameter `gw/reg_no_conn_info` contains the decimal representation of a bit vector. For Kernel below 7.40 at least bit 1, 2, 3, and 4 must be set. As of Kernel 7.40 at least bit 1 must be set (bit 2, 3 and 4 are not relevant anymore).
Therefore, the allowed values for Kernel below 7.40 are 15, 31, 47, 63, 79, 95, 111, 127, 143, 159, 175, 191, 207, 223, 239, 255.
For Kernel as of 7.40 the value must be uneven.
The recommended value is 255. (see note [2776748](#)) [Critical]
- d) The RFC Gateway's default "Initial Security Environment" must be enabled by setting profile parameter `gw/acl_mode = 1`³ [Critical]
- e) RFC Gateway monitoring must be set to "local only" by setting profile parameter `gw/monitor = 1` [Critical]

³ Attention! This can break communication connections, if the Gateway Access Control lists are not existing or not linked via the profile parameters correctly!

SAP Security Baseline Template

- f) The simulation mode must be off by setting profile parameter `gw/sim_mode = 0` [Critical]
- g) Use an acceptable method to start programs via the RFC Gateway by setting profile parameter `gw/rem_start = DISABLED` or `SSH_SHELL`. [Extended]
- h) Set profile parameter `gw/acl_mode_proxy = 1` and maintain the Access Control List file `prxyinfo` (the file name is defined with profile parameter `gw/prxy_info`), see note [3224889](#) [Extended]

RFCGW-J: RFC Gateway Security (part of application server Java)

The rules from `RFCGW-A` apply for Java systems as well.

RFCGW-O: RFC Gateway Security (stand-alone)

The rules from `RFCGW-A` apply for stand-alone systems as well.

TRUST: Trusting relations between systems

The general requirement is about configuring only needed trusting relations and about controlling the scope of them.

TRUST-A: Trusting relations and trusted destinations – ABAP

You define trusting relations between ABAP based systems for RFC and http in transaction `SMT1`. You define trusted RFC and http destinations in transaction `SM59`.

- a) Define only required trusting relationships in called systems. Therefore, remove any unused or unwanted trusting relationship. [Critical]
- b) Define only required trusted destinations in calling systems. Therefore, remove any unused or unwanted trusted destination. [Critical]
- c) All trusting relationships should use the latest security method. Therefore, you have to migrate existing old trusting relationships in called systems and you have to migrate the corresponding trusted destinations in calling systems according to note [3157268](#). [Critical]
- d) Use SNC respective TLS on top of trusted connections. [Extended]
- e) Trusting relationships are configured to use the transaction code field for authorization object `S_RFCACL`. [Extended]
- f) Set profile parameter `rfc/selftrust = 0` to block implicit self-trust between the clients of an ABAP system. [Standard]
- g) Assign authorizations to manage trusting relations about authorization object `S_RFC_ADM_TT` only to few administrators. [Critical]
- h) Control authorizations in called systems which allow using trusting relations via authorization object `S_RFCACL` strictly (no * value for calling system id and client) and separate the two use-cases (technical user vs. same user) in different authorizations. [Critical]
- i) Use authorizations object `S_ICF` in calling systems to secure critical trusted destinations. [Extended]
- j) Set profile parameter `rfc/allowolddticket4tt = no` to block old trusted tickets. (see note [3157268](#)) [Extended]

SSO: Single Sign-On

Single Sign-On tickets must be protected appropriately during transport.

SAP Security Baseline Template

SSO-A: Single Sign-On – ABAP

- a) Profile parameter `login/ticket_only_by_https = 1`
(generate ticket that will only be sent via https)
This setting requires according entries in customizing table `HTTPURLLOC` to force the URL generation to produce https URLs only. (see notes [1531399](#) and [2068872](#)) [Standard]
- b) Profile parameter `login/ticket_only_to_host = 1`
(ticket will only be sent back to creating host) [Standard]
- c) Profile parameter `icf/set_HTTPOnly_flag_on_cookies <> 1` or 3, the recommended value is 0
(HTTPOnly attribute should be active for ICF logon cookie) (see notes [2068872](#) and [1277022](#)) [Standard]
- d) Profile parameter `login/accept_sso2_ticket = 2` to accept SAP Assertion Tickets, but reject SAP Logon Tickets (see note [3584984](#)) [Standard]

SSO-J: Single Sign-On – Java

- a) UME property `ume.logon.security.enforce_secure_cookie` must be set to `true` to enforce transmission of logon cookies over HTTPS only via the `Secure` cookie property. (see note [2068872](#)) [Extended]
- b) UME property `ume.logon.httponlycookie` must be set to `true` to protect logon cookies via the `HttpOnly` cookie flag against Javascript access and Cross Site Scripting attacks. (see note [2068872](#)) [Extended]
- c) UME property `login.ticket_lifetime ≤ 8` (SAP Logon Ticket Lifetime hh:mm) [Extended]
- d) Set the `portal.alias.security.enforce_secure_cookie` property value to `true`. (see documentation at [Securing the Portal Alias Cookie](#)) [Extended]

IDPROV: Identity Provider

IDPROV-P: Identity Provider – BTP

- a) A custom platform identity provider should be configured for the global account platform user authentication. [Standard]
- b) A custom platform identity provider should be configured for subaccount platform user authentication. [Standard]
- c) A custom platform identity provider should be configured for Cloud Foundry organization member and Cloud Foundry space member authentication. [Standard]
- d) A custom application identity provider should be configured for business user authentication. [Standard]
- e) The number of active identity providers for the global account/subaccounts should be tightly restricted. [Extended]
- f) We recommend that you keep at least one administrator of the global account, each subaccount and each Cloud Foundry organization from the default identity provider. You can then use this administrator to log on in the rare instance that access to the custom identity provider fails. [Standard]

SAP Security Baseline Template

2.3.3 Roles and Authorizations

CRITAU: Critical Authorizations

User should have minimal Authorization – if not needed should not have critical Authorizations.

CRITAU-A: Critical Authorizations – ABAP

- a) No use of ABAP authorization profile `SAP_ALL` [Critical]
- b) No use of ABAP authorization profile `SAP_NEW` and role `SAP_NEW` [Critical]
- c) Restricted assignment of critical ABAP basis authorizations [Critical]

The assignment of critical basis authorization should be tightly controlled. Especially the assignment of the following critical basis authorizations should be avoided or limited as far as possible:

- 1) Authorization to change or display all tables (`S_TABU_DIS` * respective `S_TABU_NAM` *)
- 2) Authorization to start all transactions, services and applications (`S_TCODE` * and `S_SERVICE` * and `S_START` *)
- 3) Authorization to start all reports (`S_PROGRAM` *)
- 4) Authorization to debug / replace (`S_DEVELOP` for `DEBUG` with activity 01/02 and `S_DBG` with activity 02 for ABAP Platform 2022 on SAP_BASIS 7.57 or higher according to note 65968)
- 5) Authorization to display other users' spool request (`S_SPO_ACT`)
- 6) Authorization to administer RFC connections (`S_RFC_ADM`)
- 7) Authorization to execute all Function Modules (`S_DEVELOP` for `FUGR` with activity 16) in the development workbench
- 8) Authorization to execute all Class Methods (`S_DEVELOP` for `CLAS` with activity 16) in the development workbench
- 9) Authorization to reset/change user passwords or to lock/unlock users (`S_USER_GRP` with activity 05)
- 10) Authorization to create/change/delete users (`S_USER_GRP` with activity 01, 02, or 06)
- 11) Authorization to change the authorization groups of tables (`S_TABU_DIS` with activity 02 for table authorization group `SS`)
- 12) Authorization to administer queries (`S_QUERY` with activity 23)
- 13) Authorization to call all RFCs (`S_RFC` *)
- 14) Authorization to execute any update commands in the DBA Cockpit SQL Editor (`S_DBCON` with activity 36)
- 15) Authorization to read all database tables in the DBA Cockpit SQL Editor (`S_TABU_SQL` *)

d) Protection of Password Hashes in ABAP Systems

- 1) Ensure that tables `USR02`, `USH02` and `USRPWDHISTORY` are assigned to table authorization group `SPWD`. [Standard]
- 2) Access to tables `USR02`, `USH02` and `USRPWDHISTORY` using standard tools like transactions `SE16`, `SE16N` or `SM30` must be protected against unauthorized access by the

SAP Security Baseline Template

means of restricted authorizations for authorization object `S_TABU_DIS` (for table authorization group `SPWD`) respectively `S_TABU_NAM` (for the named tables). [Standard]

CRITAU-J: Critical Authorizations – Java

- a) No users other than system administrators may belong to the standard group `Administrators` (for single stack installations) or `SAP_J2EE_ADMIN` (for dual stack installations). [Standard]

CRITAU-H: Critical Authorizations – HANA

- a) The system privilege `DATA ADMIN` must not be granted neither to a user nor to a role. [Critical]

CRITAU-P: Critical Authorizations – BTP

The following requirements apply to the global account and directories only.

- a) The default platform role collections `Global Account Administrator` and `Directory Administrator` should only be assigned to a minimal count of platform users. [Standard]

The following requirements apply to multi-environment subaccounts only.

- b) The default platform role collection `Subaccount Administrator` containing all critical subaccount roles should only be assigned to a minimal count of platform users. [Standard]

The following requirements apply to platform users (members) of Cloud Foundry organizations and spaces only.

- c) The Cloud Foundry roles `Org Manager`, `Space Manager` and `Space Developer` should only be assigned to a minimal count of members. [Standard]

The following requirements apply to Neo environment subaccounts only.

- d) The default platform role `Administrator` containing the critical scope `manageCustomPlatformRoles` should only be assigned to a minimal count of platform users. [Standard]
- e) Custom platform roles containing the critical platform scope `manageCustomPlatformRoles` should only be assigned to a minimal count of platform users. [Standard]
- f) HTML5 application permission `NonActiveApplicationPermission` must not be assigned to roles other than developer roles like `AccountDeveloper`. [Critical]
- g) A dedicated HTML5 application permission for the application descriptor `neo-app.json` must be available and should not be assigned to a business user role. [Standard]
- h) Platform API OAuth clients with the critical scopes `Manage Authorization`, `Manage Account Members` or `Manage Audit Logs` must be limited to the required minimum. [Standard]

AUTHASSIGN: Assignment of Authorizations

Authorizations should get assigned via groups or roles to allow a transparent and consistent authorization assignment.

AUTHASSIGN-A: Assignment of Authorizations – ABAP

Do not transport role assignments

SAP Security Baseline Template

- a) Prohibit direct user assignments while exporting transports using customizing settings
US_ASGM_TRANSPORT = NO in table PRGN_CUST. This requirement is important for development systems. See note [1723881](#) [Standard]
- b) Prohibit direct user assignments while importing transports using customizing settings
USER_REL_IMPORT = NO in table PRGN_CUST. See note [571276](#) and https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbcccf/6d7c8cfd410ea040aadf92e1f78107a4.html [Standard]

AUTHASSIGN-P: Assignment of Authorizations – BTP

The following requirements apply to Neo environment subaccounts only.

- a) The Java application should not have individual user-to-role assignments in place. [Standard]
- b) HTML5 applications should not have individual user-to-role assignments in place. [Standard]
- c) Subscriptions for Java or HTML5 applications should not have individual user-to-role assignments in place. [Standard]

2.3.4 Custom Code Security

Currently there are no specific regulations in this chapter.

2.4 Process

2.4.1 Regulatory Process Compliance

Currently there are no specific regulations in this chapter.

2.4.2 Data Privacy and Protection

SECSTO: Protection of Secure Store

SECSTO-A: Protection of Secure Store – ABAP

Set an individual main key using transaction SECSTORE (respective report RSEC_KEY_WIZARD) according to notes [1902611](#) and [1902258](#). [Extended]

SECSTO-J: Protection of Secure Store – Java

Encryption for the Secure Store must be activated, see “Managing Secure Store Data” at <https://help.sap.com/viewer/0c333adb55cd4dbf8e92a5175703224c/7.4.19/en-US/47b08e68542e3378e10000000a421937.html>. [Extended]

2.4.3 Audit and Fraud Management

AUDIT: Audit Settings

Security-relevant audit logs must be activated and at least critical must be recorded, so that it is possible to identify and analyze potential attacks either current or in retrospect.

AUDIT-A: Audit Settings – ABAP

- a) The Security Audit Log must be activated by setting several profile parameters [Standard]
 - rsau/enable = 1
 - rsau/integrity = 1

SAP Security Baseline Template

rsau/log_peer_address = 1 (see Note [2190621](#))

rsau/selection_slots ≥ 10

rsau/user_selection = 1

The same requirement holds for the Security Audit Log Kernel Parameters which you can define with transaction SM19 respectively RSAU_CONFIG: "Security Audit active", "Number of Selection Filters", "Generic User Selection", and "protection format active".

- b) At least the following Security Audit Log slots must be defined and activated: [Standard]

Audit all events for critical standard users SAP* (using filter SAP#*), DDIC (if not used for job RDDIMPDP) and SAPCPIC (if the user still exists) in all clients (plus full log for 066)

Audit all events for additional critical users like emergency users or support users in all clients

Audit critical events for all users in all clients

- c) Monitoring of the Internet Communication Manager (ICM) must be active by setting several profile parameters.

The following list shows the recommended settings according to security setting of S/4HANA (see note [2926224](#)). You may use different settings. [Standard]

icm/HTTP/logging_0 =

PREFIX=/, LOGFILE=http_%y_%m.log, MAXFILES=2, MAXSIZEKB=50000, SWITCHTF=month, LOGFORMAT=%t %a %u1 \"%r\" %s %b %Lms %{Host}i %w1 %w2

icm/HTTP/logging_client_0 =

PREFIX=/, LOGFILE=http_client_%y_%m.log, MAXFILES=2, MAXSIZEKB=50000, SWITCHTF=month, LOGFORMAT=%t %a %u1 \"%r\" %s %b %Lms %{Host}i

icm/security_log =

LOGFILE=\$(DIR_LOGGING)\$(DIR_SEP)dev_icm_sec-%y-%m-%d%z, LEVEL=3, MAXFILES=7, MAXSIZEKB=50000, SWITCHTF=day, FORMAT=TABLE

(see note [3581719](#))

- d) Monitoring of the Message Server must be active by setting several profile parameters.

The following item shows the recommended settings according to security setting of S/4HANA (see note [2926224](#)). You may use different settings. [Standard]

ms/HTTP/logging_0 = PREFIX=/, LOGFILE=\$(DIR_LOGGING)/ms-

http-%y-%m-%d.log%o, MAXFILES=7, MAXSIZEKB=10000, SWITCHTF=day, LOGFORMAT=%t %a %u %r %s %b %{Host}i

ms/http_logging = 1

AUDIT-J: Audit Settings – Java

The Log Viewer application in SAP NetWeaver Administrator allows uploading of external log files and therefore should validate XML documents from an untrusted source. Set Java property enable.xml.hardener = true according to note [2372626](#). [Extended]

AUDIT-H: Audit Settings – HANA

The HANA Audit Trail must be activated with the following minimum requirements:

- a) Auditing Status must be enabled

File global.ini section auditing configuration parameter

global_auditing_state = true OR TRUE [Critical]

- b) Audit Level Trail Targets must be Initial or contain at least one of the targets

SYSLOGPROTOCOL (Syslog) or CSTABLE (Database Table) for each of the Audit Trail Targets. It

SAP Security Baseline Template

may contain multiple selections including CSVFILE (CSV Text File). However, "CSV Text File" should not be used to log security-critical information.

File global.ini section auditing configuration parameter

default_audit_trail_type = SYSLOGPROTOCOL or CSTABLE

[Standard]

c) Define audit policies according to the best practices.

see:

Best Practices and Recommendations for Creating Audit Policies

https://help.sap.com/docs/SAP_HANA_PLATFORM/b3ee5778bc2e4a089d3299b82ec762a7/35eb4e567d53456088755b8131b7ed1d.html

and note [3016478](#) respective proposals at GitHub

<https://github.com/SAP-samples/s4hana-hana-audit-policies>

[Standard]

Sample from a customer environment:

No	Policy	Audited Actions	Audit Action Status	Level	Users
1	Z_CONFIGURATION_CHANGES	SYSTEM CONFIGURATION CHANGE	SUCCESSFUL	WARNING	
2	Z_CONNECT_UNSUCCESSFUL	CONNECT	UNSUCCESSFUL	WARNING	
3	Z_EXECUTE_PROCEDURE_ROLE	EXECUTE on GRANT_ACTIVATED_ANALYTICAL_PRIVILEGE, GRANT_ACTIVATED_ROLE, GRANT_APPLICATION_PRIVILEGE, GRANT_PRIVILEGE_ON_ACTIVATED_CONTENT, GRANT_SCHEMA_PRIVILEGE_ON_ACTIVATED_CONTENT, REVOKE_ACTIVATED_ANALYTICAL_PRIVILEGE, REVOKE_ACTIVATED_ROLE, REVOKE_APPLICATION_PRIVILEGE, REVOKE_PRIVILEGE_ON_ACTIVATED_CONTENT, REVOKE_SCHEMA_PRIVILEGE_ON_ACTIVATED_CONTENT plus any other protected procedure	ALL	WARNING	
4	Z_GRANT_REVOKE_ROLE_PRIV	GRANT ANY, REVOKE ANY	ALL	CRITICAL	
5	Z_REPO_CHANGES	ACTIVATE REPOSITORY CONTENT, EXPORT REPOSITORY CONTENT, IMPORT REPOSITORY CONTENT	ALL		
6	Z_SAPABAP1_SUCCESSFUL_LOGON*	CONNECT	SUCCESSFUL	INFO	SAPABAP1
7	Z_SAPABAP1_UNSUCCESSFUL_LOGON	CONNECT	UNSUCCESSFUL	CRITICAL	SAPABAP1
8	Z_SCHEMA_CHANGES	EXECUTE, DELETE, UPDATE, INSERT	ALL	INFO	except for SAPABAP1
9	Z_SCHEMA_CHANGES_DML	CREATE TABLE, ALTER TABLE, DROP TABLE, CREATE VIEW, ALTER VIEW, DROP VIEW, CREATE PROCEDURE, ALTER PROCEDURE, DROP PROCEDURE, CREATE SCHEMA, DROP SCHEMA	ALL	INFO	except for SAPABAP
10	Z_SYSTEM_ALL_ACTIONS	ALL_ACTIONS	ALL	INFO	SYSTEM
11	Z_SYSTEM_ALTER_USER	ALTER USER	ALL	CRITICAL	SYSTEM
12	Z_SYSTEM_UNSUCCESSFUL_LOGON	CONNECT	UNSUCCESSFUL	CRITICAL	SYSTEM
13	Z_USER_MAINTENANCE	CREATE USER, ALTER USER, DROP USER, CREATE ROLE, ALTER ROLE, DROP ROLE, CREATE USERGROUP, ALTER USERGROUP, DROP USERGROUP	ALL	INFO	

*Policy disabled due to the amount of events

Audit Levels Principles:

SAP Security Baseline Template

level `INFO` can be used for events that should not be reviewed immediately but are kept in case a forensic analysis should be done.

level `CRITICAL` can be used for events that with high probability generate a security incident,

level `WARNING` for all remaining events. It also depends on the absolute numbers of events.

Definitions:

`Z_CONFIGURATION_CHANGES LEVEL WARNING` → Normally, the configuration should not be changed frequently in the productive environment, thus level `WARNING` to draw auditor's attention to these events.

`Z_USER_MAINTENANCE LEVEL INFO` → Just creating a user without granting some privileges is not really critical from security point of view, thus just level `INFO` mainly for forensic reasons.

`Z_GRANT_REVOKE_ROLE_PRIV LEVEL CRITICAL` → Granting or revoking privileges is critical from security perspective, thus level `CRITICAL` to highlight these events, actually it can be decreased to `WARNING` to be conform to `Z_EXECUTE_PROCEDURE_ROLE`.

`Z_EXECUTE_PROCEDURE_ROLE LEVEL WARNING` → Same as above, but if I understand your setup correctly it will not be used in the daily business.

`Z_REPO_CHANGES LEVEL WARNING` → Same motivation as for `Z_CONFIGURATION_CHANGES`

`Z_CONNECT_UNSUCCESSFUL LEVEL WARNING` → It might indicate brute-forcing password guessing, such event sequences should be reviewed regularly.

`Z_SYSTEM_ALTER LEVEL CRITICAL` → Normally, it should occur only in case of preparing for system patch, etc. Thus, level `CRITICAL` to draw attention to these events.

`Z_SYSTEM_UNSUCCESSFUL_LOGON LEVEL CRITICAL` → Is an indicator for password guessing attack, it should create a security incident.

`Z_SCHEMA_CHANGES LEVEL INFO` → In case authorization are granted properly such actions are not directly security relevant. Thus, level `INFO` mainly for forensic reasons.

`Z_SCHEMA_CHANGES_DML LEVEL INFO` → Same as above

`Z_SAPABAP1_SUCCESSFUL_LOGON LEVEL INFO` → High number of events is expected. To not pollute audit log with critical events, just level `INFO` mainly for forensic reasons.

AUDIT-P: Audit Settings – BTP

- a) A process for fetching the audit logs per subaccount on a regular basis and storing them in another persistent storage should be established. [Standard]
- b) The Audit Log Level of the Cloud Connector(s) should be set to `Security`. [Standard]

2.5 Organization

Similar to the “Environment” layer, this “Organization” layer is also important to set the environment for SAP systems and SAP cloud solutions. It sets the stage and gives needs and requirements as input to be considered.

2.5.1 Awareness

Currently there are no specific regulations in this chapter.

SAP Security Baseline Template

2.5.2 Security Governance

Currently there are no specific regulations in this chapter.

2.5.3 Risk Management

Currently there are no specific regulations in this chapter.

SAP Security Baseline Template

3 Addendum

3.1 Requirements Details

3.1.1 Requirements List

AUDIT: Audit Settings

AUDIT-A: Audit Settings - ABAP

Recommended filter settings:

1. Filter: Activate everything which is critical for all users '*' in all clients '*'.

- a) You may deactivate the messages of class "User master record change (32)" because you get change documents in transaction SUIM anyway.
- b) Consider adding messages AUO, AUZ, BU5, BU6, BU7, BU9, BUA, BUB BUC, BUH, AUP, AUQ
- c) If you maintain logical file names (see SAP note [1497003](#)) then add messages CUQ, CUR, CUS, CUT (use either use a single filter for all items or use one filter per line.)

2. Filter: Activate everything for special user SAP* in all clients '*'

You cannot use a filter SAP* because this would include the virtual user SAPSYS because of profile parameter `rsau/user_selection = 1`. This virtual user SAPSYS performs many house-keeping activities triggered by the system itself. You do not want to log these events.

However, you can use the special filter value SAP#* instead.

Hint: You can use this special filter value SAP#* as well in transaction SM20 respectively `RSAU_READ_LOG` or reports `RSAU_SELECT_EVENTS` and `RSAU_READ_LOG` to show log entries in for user SAP* only.

3+4. Filter: Activate everything for other support and emergency users, e.g. SAPSUPPORT* (SAP Support users) respective FF* (FireFighter) in all clients '*'.

5. Filter: Activate all events for audit classes dialog logon, RFC logon and transaction start for user DDIC* in all clients '*'

Filter	Client	User Name	Audit Classes	Event Level
1	*	*	all	critical
2	*	SAP#*	all	all
3	*	SAPSUPPORT* (User IDs for SAP-Support)	all	all
4	*	FF* (Emergency User IDs)	all	all
5	*	DDIC	dialog logon, RFC logon, transaction start	all

AUDIT-P: Audit Settings - BTP

- a) A process for fetching the audit logs per subaccount on a regular basis and storing them in another persistent storage should be established.

SAP Security Baseline Template

The following topics apply to Neo environment subaccounts only.

We recommend to create a dedicated platform API client with scope “Read Audit Logs” and to fetch the audit logs regularly using the Audit Log Retrieval API.

Audit logs get automatically deleted after the defined retention period. The retention period can be changed using the SAP BTP Audit Log Retention API. By default, the audit log data stored for your account will be retained for 201 days, after which it will be deleted.

See SAP Help Portal:

- [Audit Log Retrieval API Usage for the Neo Environment](#)
- [Audit Log Retention API Usage for the Neo Environment](#)

The following topics apply to multi-environment subaccounts only.

The SAP Audit Log service is a platform service which stores all the audit logs written on your behalf by other platform services that you use. It allows you to retrieve the audit logs for your subaccount via the Audit Log Retrieval API or view them using the SAP Audit Log Viewer service.

The audit log data stored for your account will be retained for 90 days, after which it will be deleted. Therefore, it is important to store them in another persistent storage.

The retention period for audit logs in the BTP Cloud Foundry environment cannot be changed.

Gathering audit log information on a regular basis and storing them in another persistent storage can be done by exporting the audit logs using the SAP Audit Log Viewer service or via the Audit Log Retrieval API.

See SAP Help Portal:

- [Audit Logging in the Cloud Foundry Environment](#)
- [Audit Log Retrieval API Usage for Subaccounts in the Cloud Foundry Environment](#)
- [Audit Log Viewer for the Cloud Foundry Environment](#)

b) The Audit Log Level of the Cloud Connector(s) should be set to Security.

Audit Log Level Security:

Default value. The Cloud Connector writes an audit entry (Access Denied) for each request that was blocked. It also writes audit entries, whenever an administrator changes one of the critical configuration settings, such as exposed back-end systems, allowed resources, and so on.

See SAP Help Portal:

- [Audit Logging](#)
- [Manage Audit Logs](#)

Related Checks in EWA and SOS

In the **SOS** (Security Optimization Service for ABAP), the following checks apply

- Security Audit Log is not active (0170)
- User SAP*'s activities are not logged in the Security Audit Log (0047)

AUTHASSIGN: Assignment of Authorizations

Authorizations should get assigned via groups or roles to allow a transparent and consistent authorization assignment.

SAP Security Baseline Template

AUTHASSIGN-A: Assignment of Authorizations – ABAP

- a) Prohibit direct user assignments while exporting transports. This requirement is important for development systems.
See note [1723881](#) and https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbcccf/8a922c9d7bca45c9b29bff3c59b344df.html
- b) Prohibit direct user assignments while importing.
See note [571276](#) and https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbcccf/6d7c8cfd410ea040aadf92e1f78107a4.html

AUTHASSIGN-P: Assignment of Authorizations – BTP

The following topics apply to Neo environment subaccounts only.

We recommend to assign a set of required roles for a particular task to a group, which allows an easy management of required authorizations to a dedicated collection of users instead of individual users.

Furthermore, it is recommended to automate the user-to-group assignment via “assertion-based groups” or via Identity Provisioning Service.

CHANGE: Protect Production System against changes

CHANGE-A: Protect Production System against changes – ABAP

Corresponding Configuration Store `CLIENTS`

SAP Security Baseline Template

Possible field values:

T000-CCCATEGORY Role of client

- C Customizing
- D Demo
- E Training/Education
- P Live
- S SAP reference
- T Test

T000-CCCORACTIV Changes and transports for client-specific objects

No automatic recording of changes for transport

- 1 Changes are recorded in transport request
- 2 Customizing in this client cannot be changed
- 3 Customizing: Can be changed as request, but cannot be transported

T000-CCNOCLIIND Maintenance authorization for objects in all clients

Changes allowed to repository and cross-client customizing

- 1 No changes to cross-client customizing objects
- 2 No changes to repository objects
- 3 No changes to repository and cross-client customizing objects

T000-CCCOPYLOCK Protection regarding client copy program and comparison tools

Protection level 0: No restriction

- X Protection level 1: No overwriting
- L Protection level 2: No overwriting, no external availability for read-access

T000-CCNOCASCAD Client control: No client cascade for upgrade import

No

- X Yes

- a) Local customizing settings (aka “running settings”) are still possible and should be logged. The main switch for logging customizing changes, profile parameter `rec/client` should be activated either by value `ALL` or a list of clients.
Corresponding Configuration Store `ABAP_INSTANCE_PAHI`

You may want to validate if critical tables are defined with active table logging (Transaction `SE11` → “Technical settings” respective transaction `SE13`).

You can use report `RDDPRCHK` (or old report `RDDTDDAT_BCE` respective transaction `STDDAT` in newer releases) to check various settings of tables:

- Table Authorization Group assignment
Corresponding Configuration Store `TDDAT`
- Delivery Class (S, W for system tables, A, L for application tables, C, E G for customizing tables)
- Table Maintenance Status (no access using `SE16`, display using `SE16`, change using `SE16`)
- Logging for customizing tables (on, off)
Corresponding Configuration Store `LOGGED_TABLES`

- b) You control if customizing table logs get produced during imports of transports using the transport parameter `RECCLIENT`. Activate this setting especially if your customizing

SAP Security Baseline Template

development system (where you get table logs using profile parameter `rec/client`) is not stable.

Corresponding Configuration Store `TRANSPORT_TOOL`

As of S/4HANA 2021 you find these settings in table `TPSYSTEMDEFAULT`.

- c) You control if repository objects like programs or tables get versioned during transports using the transport parameters `VERS_AT_EXP` (versioning in development system) and `VERS_AT_IMP` (versioning in production system). Activate `VERS_AT_IMP` especially if your development system is not stable.

Corresponding Configuration Store `TRANSPORT_TOOL`

- d) According to security note [2671160](#) you should activate transport parameter `TLOGOCHECK` to validate the content of transport files.

Corresponding Configuration Store `TRANSPORT_TOOL`

- e) According to the same note you should install at least a specific version of the Kernel respective tp/R3trans.

Validate the Kernel release or the transport parameters `TP_RELEASE` (which shows the currently installed version of tp and which is only available in the Configuration Store) respective `TP_VERSION` (which shows the minimal required version of tp according to your transport tool settings in transaction `STMS`)

See note [2671160](#) for minimal version information – you can either check the version of the Kernel or the version of R3trans (the required version of tp is not listed in the note anymore):

Kernel 721 patch 1112

Kernel 722 patch 625

Kernel 745 patch 810

Kernel 749 patch 521

Kernel 753 patch 220

Kernel 773 patch 220

Kernel 774 patch 0

R3trans: patch level 1119

R3trans: patch level 715

R3trans: patch level 824

R3trans: patch level 615

R3trans: patch level 312

R3trans: patch level 25

R3trans: patch level 12

Corresponding Configuration Store `TRANSPORT_TOOL`

CRITAU: Critical Authorizations

CRITAU-A: Critical Authorizations – ABAP

- a) No use of ABAP authorization profile `SAP_ALL`

An exception from this rule is possible for emergency accounts if the activation and use of such emergency accounts is sufficiently controlled and monitored.

- b) No use of ABAP authorization profile `SAP_NEW` and role `SAP_NEW`

An exception from this rule is possible only while preparing the technical part of a release upgrade.

See blog “Life (profile `SAP_NEW`), the Universe (role `SAP_NEW`) and Everything (`SAP_ALL`)”

<https://scn.sap.com/community/security/blog/2014/02/17/life-profile-sapnew-the-universe-role-sapnew-and-everything-sapall>

- c) Restricted Assignment of Critical ABAP Basis Authorizations

For 1. Authorization object `S_TABU_DIS` you can add checks for critical table groups like `&NC&` (which covers all tables or views which are not assigned to a group) or `FA`, `PA`, `SA`, etc.

SAP Security Baseline Template

- d) The assignment of critical basis authorization should be tightly controlled. Protection of Password Hashes in ABAP Systems

SAP note [1484692](#) lists some more tables. You may want to include these tables as well.

CRITAU-H: Critical Authorizations – HANA

- a) *Currently there is no additional information for this requirement available.*

CRITAU-P: Critical Authorizations – BTP

- a) *Currently there is no additional information for this requirement available.*
b) *Currently there is no additional information for this requirement available.*
c) *Currently there is no additional information for this requirement available.*

The following topics apply to Neo environment subaccounts only.

- d) The default platform role `Administrator` containing the critical scope `manageCustomPlatformRoles` should only be assigned to a minimal count of platform users.

Platform roles including the scope `manageCustomPlatformRoles` allow platform users to change custom platform roles in all subaccounts (productive and non-productive) of this global account belonging to the same region thus potentially tampering with other subaccounts.

You find the documentation about platform scopes of the BTP Neo environment on the SAP Help Portal: [Platform Scopes](#)

- e) Custom platform roles containing the critical platform scope `manageCustomPlatformRoles` should only be assigned to a minimal count of platform users.

Platform roles including the scope `manageCustomPlatformRoles` allow platform users to change custom platform roles in all subaccounts (productive and non-productive) of this global account belonging to the same region thus potentially tampering with other subaccounts.

You find the documentation about platform scopes of the BTP Neo environment on the SAP Help Portal: [Platform Scopes](#)

- f) HTML5 application permission `NonActiveApplicationPermission` must not be assigned to roles other than developer roles like `AccountDeveloper`.

The HTML5 application permission `NonActiveApplicationPermission` should only be assigned to developer roles like `AccountDeveloper`. This is very critical as other users than developers otherwise could access old application versions which may contain an outdated authorization concept and/or insecure code.

See SAP Help Portal: [Application Descriptor File - Authorization](#)

- g) A dedicated HTML5 application permission for the application descriptor `neo-app.json` must be available and should not be assigned to a business user role.

By default, business users can access the application descriptor file of an HTML5 application. As the information contained in the application descriptor could be useful for attackers (e.g. this permission is required to access a protected resource), it should not be exposed to business users.

For security reasons we recommend that you use a permission to protect the application descriptor from being accessed by business users and to assign a developer-only role to this permission (example: `AccountDeveloper` role).

See SAP Help Portal: [Protecting the Application Descriptor](#)

SAP Security Baseline Template

- h) Platform API OAuth clients with the critical scopes `Manage Authorization`, `Manage Account Members` or `Manage Audit Logs` must be limited to the required minimum.

The scope `Manage Authorization` belongs to the authorization management REST API and provides functionality to manage roles and their assignments to users for all applications, application subscriptions and services in this subaccount.

See SAP Help Portal: [Authorization Management API](#)

The scope `Manage Account Members` belongs to the Platform Authorizations Management API and allows you to manage the users authorized to access your subaccount.

See SAP Help Portal: [Platform Authorization Management API](#)

The scope `Manage Audit Logs` belongs to the audit log retention API and allows to change the active retention period for the audit log data of the subaccount. If the retention period is set to 1, respective subaccount audit log data gets erased after one day and may get lost forever if there is no regular backup in place using the audit log retrieval API. We recommend to not assign the critical scope `Manage Audit Logs` to any client, as changing the audit log retention period is typically a one-time action during the initial subaccount setup. If it is required to change the audit log retention period at a later point in time, create a dedicated platform API OAuth client exactly for this purpose and delete it after the changes have been applied.

See SAP Help Portal: [Audit Log Retention API](#)

Related Checks in EWA and SOS

In the **SOS** (Security Optimization Service), the following checks apply

SOS ABAP:

- Additional Super User Accounts Found (0022)
- Not all profiles are removed from user SAP* (0042)
- User `SAPCPIC` Has More Authorizations Than Required (0054)
- Profile of User `SAPJSF` (0796)
- Users with Profile `SAP_NEW` (0031)
- Users - Other Than Key Users - Are Authorized to Start All Reports (0512)
- Users - Other Than Key Users - Are Authorized to Display All Tables (0513)
- Users Are Authorized to Maintain All Tables (0514)
- Users Are Authorized to Debug and Replace Field Values in the Production System (0308)
- Users - Other Than Spool Administrators - Are Authorized to Display Other Users Spool Requests (0192)
- Users - Other Than System Administrators - Are Authorized to Administer RFC Connections (0255)
- Users Are Authorized to Execute All Function Modules (0520)
- Users - Other Than User Administrators - Are Authorized to Change Passwords (0121)
- Users - Other Than System Administrators - Are Authorized to Change the Authorization Group of Tables (0515)
- Users - Other Than Query Administrators - Are Authorized to Administer Queries (0517)
- Users Are Authorized to Run Any RFC Function (0241)

SAP Security Baseline Template

CUSTOM: Custom Code Security

Currently there are no specific regulations in the corresponding chapter.

The development of secure custom applications requires measures for the organization, knowledge, tests and code scans.

Examples:

- Segregation between development, transport management, and quality assurance teams
- Secure development guide (e.g. based on the chapter "ABAP – Security Notes" in the Keyword Documentation in the system and the Online Documentation at <https://help.sap.com/viewer/1a93b7a44ac146b5ad9b6fd95c1223cc/7.4.21/en-US>)
- Manual code review as part of a quality gate
- Automated code scans (in case of ABAP, e.g. using the Code Vulnerability Analyzer, CVA)

DISCL: Information Disclosure

Disclosure of unnecessary information about versions or from errors must be prohibited.

DISCL-A: Information Disclosure – ABAP

Both profile parameters, `login/show_detailed_errors` (see note [1823687](#)) and `is/HTTP/show_detailed_errors` (see notes [1616535](#), [2206951](#)), are relevant for ABAP-based systems to control which information is shown in case of failed web-based logons.

The Internet Communication Manager of ABAP systems and the Web Dispatcher (stand-alone) both have following security requirements:

- a) Instead of `is/HTTP/show_detailed_errors = FALSE` also individual error pages can be made available and referred to via `icm/HTTP/error_tmpl_path` – see notes [870127](#) and [1616535](#) for details.
- b) Use the SAP Web Dispatcher as a URL Filter according to note [870127](#) and the online help chapter "[SAP Web Dispatcher as a URL Filter](#)".

Note that the URI permission table is case sensitive. Since the URI permission table is case sensitive, it is important to create the table as a positive list. Enter the rules into a file. You must maintain profile parameter `wdisp/permission_table` to address this file.

7.31: In addition to the URL filter function described here the authentication handler function of the Web Dispatcher provides a significantly more thorough security check. If you set up the authentication handler using parameter `icm/HTTP/auth <xx>`, you can deactivate both the configuration described here and the authentication for the Web-based administration interface (option `AUTHFILE` of the parameter).

7.50: This function is obsolete and should no longer be used. Instead, use authorization handler: Profile parameter `icm/HTTP/auth_<xx>`.

You find more information about profile parameter `service/protectedwebmethods` in the next chapter.

DISCL-H: Information Disclosure – HANA

- a) Enabling HANA data at rest encryption (data volume encryption, log encryption, backup encryption) does not harm performance. Experience has shown that performance impact of HANA data at rest encryption is not significant.
see: Note 2159014 and

SAP Security Baseline Template

Server-Side Data Encryption Services

https://help.sap.com/docs/SAP_HANA_PLATFORM/b3ee5778bc2e4a089d3299b82ec762a7/b30fda1483b34628802a8d62bd5d39df.html

- b) The keys for HANA data at rest encryption need to be stored in a safe place as these are required during recovery.
see: Root Key Backup
https://help.sap.com/docs/SAP_HANA_PLATFORM/b3ee5778bc2e4a089d3299b82ec762a7/39730482d6944173b34c660c20963051.html

DISCL-J: Information Disclosure – Java

Server Header must be disabled by setting property `UseServerHeader` to `false` in the HTTP Provider Service in the global configuration of dispatcher and server nodes.

Web methods must be protected by setting profile parameter `service/protectedwebmethods` to `SDEFAULT` with a limited list of exceptions.

References:

SAP Start Service (sapstartsrv) security

<https://wiki.scn.sap.com/wiki/display/SI/SAP+Start+Service+%28sapstartsrv%29+security>

sapstartsrv service parameters

<https://wiki.scn.sap.com/wiki/display/SI/sapstartsrv+service+parameters>

Protected web methods of sapstartsrv

<https://wiki.scn.sap.com/wiki/display/SI/Protected+web+methods+of+sapstartsrv>

Note [927637](#) - Web service authentication in sapstartsrv as of Release 7.00

Note [1439348](#) - Extended security settings for sapstartsrv

Note [2838788](#) - How to verify if service/protectedwebmethods is recognized by sapstartsrv

Protected web methods

<https://blogs.sap.com/2018/10/24/protected-web-methods/>

Samples:

Default

SDEFAULT

Solman Monitoring

SDEFAULT -ReadLogFile -ABAPReadSyslog -ListLogFilesError
-J2EEGetProcessList2 -J2EEGetProcessList

JAVA NWA System Overview

SDEFAULT -J2EEGetProcessList -PerfRead -MtGetTidByName

SUM

DEFAULT

Other Examples:

SDEFAULT -ListLogFiles -ReadLogFile -ListLogFilesError
-J2EEGetProcessList -J2EEGetThreadList2 -GetVersionInfo -ParameterValue
-PerfRead -MtGetTidByName -getTidsByName -GetAccessPointList
-GetAccessPointList2 -UtilSnglmsgReadRawdata -GWGetConnectionList
-GWGetClientList

SAP Security Baseline Template

```
SDEFAULT -GetProcessList -J2EEGetProcessList -J2EEGetThreadList  
-GetEnvironment -GetStartProfile -GetInstanceProperties -GetVersionInfo  
-ABAPGetWPTTable -GetAlertTree
```

```
SDEFAULT -ReadLogFile -ListLogFiles -J2EEGetProcessList -GetVersionInfo  
-ParameterValue
```

```
SDEFAULT -ReadLogFile -ListLogFiles -GetAlertTree -GetCIMObject
```

DISCL-O: Information Disclosure – Web Dispatcher

The Web Dispatcher (stand-alone) has the same security requirements as the Internet Communication Manager described above.

You do not need to explicitly filter the following URL patterns anymore as of Kernel 7.81 if the profile parameter `wdisp/filter_internal_uris` has the value `true` (default):

```
D /sap/public/icman/*  
D /sap/public/icf_info/*
```

According to note [870127](#) the service is called `/sap/wdisp/info`

According to the documentation for release 7.40, the service does not exist anymore:

<https://help.sap.com/viewer/621bb4e3951b4a8ca633ca7ed1c0aba2/7.4.23/en-US/489ab29948c673e8e1000000a42189b.html>

FEATAC: Feature Activation

FEATAC-P: Feature Activation – BTP

- a) You shouldn't use SAP BTP beta features in subaccounts that belong to productive enterprise accounts.
- Experimental features are not part of the officially delivered scope that SAP guarantees for future releases. This means that experimental features may be changed by SAP at any time for any reason without notice. Experimental features are not for productive use. You may not demonstrate, test, examine, evaluate or otherwise use the experimental features in a productive subaccount or with data that has not been sufficiently backed up.
- See SAP Help Portal:

- [SAP BTP - Change Subaccount Details](#)
- [Important Disclaimers and Legal Information](#)

IDPROV: Identity Provider

IDPROV-P: Identity Provider – BTP

We recommend that you configure the Identity Authentication service as the custom identity provider for platform users / members and as identity provider for business users and connect it to your own corporate identity provider.

See SAP Help Portal: [Trust and Federation with Identity Providers](#)

MSGSRV: Message Server Security

The Message Server must be configured to protect application server communication within a system and to control monitoring and administration access

SAP Security Baseline Template

MSGSRV-A: Message Server Security (part of application server ABAP or Java or stand-alone)

Currently there is no additional information for this requirement available.

MSGSRV-J: Message Server Security (part of application server ABAP or Java or stand-alone)

Currently there is no additional information for this requirement available.

Related Checks in EWA and SOS

In the **SOS** (Security Optimization Service), the following checks apply

SOS ABAP:

- Separation of Internal and External Message Server Communication (SY092)
- Message Server Administration Allowed for External Clients (SY093)
- Message Server Access Control List (SY094)

NETCF: Secure Network Configuration

NETCF-A: Secure Network Configuration – ABAP

Additional recommended organizational measures

All RFC destinations should be really required and should have a dedicated owner responsible for the destination, who can provide information on the need and usage of this destination. RFC destinations not or no longer required should be removed.

RFC destinations with stored user credentials or using trusted system logon should only exist between systems of the same security classification or from system of TRUSThigher security classification to systems of lower security classification.

Systems of higher security classification may never trust systems of lower security classification.

Several critical ICF services must be disabled if existing in the actual release. One of these services might require an exemption as it is used in some business processes:

/sap/bc/srt/IDoc

**Note [1487606](#)

If this service is used, than restrict authorizations for the corresponding authorization object B_ALE_RECV with field EDI_MES for allowed message types.

NETCF-P: Secure Network Configuration - BTP

- a) If only one Cloud Connector instance is available and goes down for some reason, cloud applications and services cannot send requests from SAP BTP to on-premise backend systems anymore.
To guarantee high availability of the connectivity for cloud integration scenarios, run productive instances of the Cloud Connector in high availability mode, that is, with a second (redundant) Cloud Connector in place.
See SAP Help Portal: [SAP BTP Connectivity / Cloud Connector – High Availability Setup](#)

NETENC: Encryption of Network Connections

NETENC-A: Encryption of Network Connections – ABAP

- a) You have to configure SNC before activating the main profile parameter `snc/enable = 1`.

SAP Security Baseline Template

- b) Keep in mind that values 1 (secure authentication only) and 2 (data integrity protection) for the profile parameters `snc/data_protection/max` and `snc/data_protection/use` do not establish encryption.
- c) If you enforce that all external RFC connections are encrypted using parameter `snc/accept_insecure_rfc = 0` you might run into performance issues for *internal* RFC connections. In this case you might want to set `snc/accept_insecure_r3int_rfc = 1` to allow unencrypted internal RFC connections.

If your SAP system is isolated by means of packet-filtering routers and you want to accept conventional connections that are not protected with SNC parallel to SNC-protected connections, then you must also set the appropriate parameters (`snc/accept_insecure_gui`, `snc/accept_insecure_rfc`, `snc/accept_insecure_cplic`).

Keep in mind that only profile parameters `snc/only_encrypted_gui` and `snc/only_encrypted_rfc` would ensure that only SNC secured connections are possible – which is beyond the scope of this security baseline (see notes [1690662](#) and [2122578](#) for details).

The inbound RFC or GUI connections should be encrypted. Set the profile parameters `snc/accept_insecure_gui = U (or 0)` and `snc/accept_insecure_rfc = U (or 0)` to enable that the logon inbound connection is secured with SNC accepting user specific exceptions.

Set the profile parameters `snc/only_encrypted_gui = 1` and `snc/only_encrypted_rfc = 1` to enforce that the logon inbound connection is secured with SNC.

- d) Set profile parameter `snc/log_unencrypted_rfc = 2` to log all unencrypted RFC connections. Use value 1 if you want to log unencrypted external RFC calls but accept unencrypted internal RFC connections.

The Security Audit Log uses message BUJ to log such events.

- e) Set profile parameter `system/secure_communication = ON` to enable authentication and encryption of the internal communication between various processes on the server (see notes [2040644](#), [2362078](#))
- f) Only if you have to support very old clients which you cannot update, set profile parameters `ssl/ciphersuites = 135:PFS:HIGH::EC_P256:EC_HIGH` and `ssl/client_ciphersuites = 150:PFS:HIGH::EC_P256:EC_HIGH` to provide TLSv1.2 but to allow TLSv1.0 as last-resort fallback to prevent interoperability problems (see note [510007](#)).

Set profile parameters `ssl/ciphersuites = 801:PFS:HIGH::EC_P256:EC_HIGH` and `ssl/client_ciphersuites = 816:PFS:HIGH::EC_P256:EC_HIGH` for limiting protocol versions to strict TLSv1.1 & TLSv1.2, which might create plenty of interoperability problems with the installed base (see note [2384290](#)).

Set profile parameter `ssl/ciphersuites = 1159:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH` and `ssl/client_ciphersuites = 1174:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH` to match the recommendations for S/4HANA 2025 (see note [3346659](#)).

- g) See previous item
- h) Set profile parameter `snc/permit_insecure_start = 0`

SAP Security Baseline Template

NETENC-O: Encryption of Network Connections – Other Components

Regarding parameter `icm/server_port_<num>`, please keep in mind that this parameter controls web protocols. Other protocols like P4 or SMTP should be secured as well.

Related Checks in EWA and SOS

In the **SOS** (Security Optimization Service), the following checks apply

SOS ABAP:

- Unsecured Outgoing RFC Calls (0252)
- SNC Protection for encrypted outgoing RFC calls (0253)
- Password Logon Is Allowed to SNC Enabled Servers (0592)

NOTEST: No Testing Functionality in Production

NOTEST-J: No Testing Functionality in Production – Java

The Java property `EnableInvokerServletGlobally` in the `servlet_jsp` service in the global configuration of server nodes which controls the Invoker Servlet is described in note [1445998](#).

OBSCNT: Obsolete Clients

In general, any operational area like a client in ABAP or a tenant in HANA, which is no longer in used, should be removed. This includes areas, which are created by default but no longer needed as well as areas, which may have been created in the past – e.g. for some testing purposes – but are no longer required.

If such an area is not in use, it is often neither maintained nor monitored. Thus, it may become a target of successful misuse by attackers,

OBSCNT-A: Obsolete Clients in ABAP

In ABAP the above general statement is especially true for clients `066` and `001`, which may have been created during system installation.

Client `066` always should be deleted. It is no longer required by SAP. Also due to client-specific coding for this client it must not be used by customers.

For client `001` it depends on whether this client is in use or not. If this client just exists, because it was created by default during system installation, but it is not used, then this client should be deleted as well.

See note [1749142](#) respectively the blog “[How to remove unused clients including client 001 and 066](#)” on SCN for additional information.

In addition, any other client, which exists but is no longer needed should be removed for the above general reason.

OBSCNT-H: Obsolete Tenants in HANA

For HANA, only the general requirement exists, that unused tenants should be removed for the general reason given above. There are no specific tenants known, for which specific comments or recommendations apply.

PWDPOL: Password Policy

Business Risk:

SAP Security Baseline Template

If someone can get the password of another user's account, depending on the corresponding authorizations critical information may be stolen, data may be changed, business processes may be misused, or systems may get infiltrated on administrative level. Even worse: It is not possible to identify on system level who did such attacks, since they are logged under the name of another user, who in fact is authorized to do, what was done.

Reason for the requirements:

There are a lot of options to control password complexity: minimum length, mixed use of different character types, checks against password history and similar. At the same time, enforcing a higher password complexity does not necessarily make passwords more secure as this motivates writing them down somewhere.

On the other side, passwords which are used by technical users and which no-one needs to remember and to enter manually during operations, may be chosen quite complex and long. The same may hold true for emergency passwords for rare exceptional cases, which are stored in a secure place until needed. And if passwords are not needed to logon at all – e.g. since all users of an ABAP system already have the possibility to logon via single sign-on – then the best recommendation may be to disable and remove the passwords completely.

So, the optimization of a suitable password policy depends on the needs, use and circumstances. Moreover, it may also differ even between different user groups in the same system.

Thus, we restricted our recommended requirements to a minimum set of very basic ones.

If a password is too short, it may be too easy to just get it. Passwords shorter than 8 characters are no longer considered as state of the art, so we propose to enforce at least this minimum.

Initial passwords are often used to get new users on-board into a system. If they are not changed within a reasonable time, then there are especially two risks: a) A user account is available but not controlled by someone using it, so an attacker may take a chance on this. b) Initial passwords are somehow communicated to the intended user. Thus, they exist somewhere outside the system – e.g. in an e-mail, in a directory or in some note – and may be grabbed and misused from there.

Last: We know, that real and even complex passwords are misused in current cyberattacks. In a preparation phase, attackers try to invade password-handling routines like logon-libraries on client systems or to install key-loggers to get all keystrokes typed by the user. Once they were successful, they grab real user-password-combinations to misuse them – often unnoticed by the victim. Thus, passwords should have a limited life-time. We propose to set it to half-a-year, but you may decide for a different value depending on your environment and needs.

In this sense, please use this SAP Security Baseline Template really as a template and modify it to your needs! We can only suggest a structure and some recommended key requirements in general and give you additional information. Only you can derive an optimized baseline for your specific situation, environment and needs!

PWDPOL-A: Password Policy – SAP AS ABAP settings

In ABAP, the profile parameter `login/min_password_lng`, respectively the policy attribute `MIN_PASSWORD_LENGTH` when using Security Policies is used to define the minimum password length

The maximum lifetime of initial passwords is defined by profile parameter `login/password_max_idle_initial`, respectively `MAX_PASSWORD_IDLE_INITIAL` when using Security Policies. A value of 0 would disable this check.

The maximum lifetime of productive passwords is defined by profile parameter `login/password_expiration_time`, respective `PASSWORD_CHANGE_INTERVAL`.

Additional technology-specific regulations:

SAP Security Baseline Template

Profile parameter `login/password_downwards_compatibility`

Depending on the setting the system creates downwards compatible passwords (using only 8 of 40 characters, case-insensitivity). (No corresponding security policy attribute)

Value 5 is prohibited since it would enforce that passwords are only saved using old / unsecure hash algorithms. Values 1-4 are not recommended either as old / unsecure hashes are generated.

Profile parameter `login/password_compliance_to_current_policy`

or `PASSWORD_COMPLIANCE_TO_CURRENT_POLICY` when using Security Policies

Enforce compliance of password with current password policy. With this configuration, users with incompatible password will be prompted for a password change in the next logon. Users of type "S" (system) and "s" (service) are not affected by this change.

Security Policies, which extend user types and password rules in ABAP, have been introduced with SAP BASIS 7.03 (= 7.00 EhP 3). See transaction `SECPOL` respectively the online help:

Security Policy Attributes for Logon and Passwords

https://help.sap.com/saphelp_nw73ehp1/helpdata/en/e9/c15fb4c06340558898fda99d98cb0d/frameaset.htm

Additional options, which you may wish to use within a system or for certain user groups, can be found in "Profile Parameters for Logon and Password (Login Parameters)" (

<https://help.sap.com/viewer/c6e6d078ab99452db94ed7b3b7bbcccf/7.4.19/en-US/4ac3f18f8c352470e1000000a42189c.html>).

Mapping between Security Policy Attributes and Profile Parameters:

Policy Attribute	Profile Parameter	Description	Kernel-Default
Logon Restrictions			
<code>DISABLE_PASSWORD_LOGON</code>	<code>login/disable_password_logon</code>	Disable Password Logon	0
<code>DISABLE_TICKET_LOGON</code>	n.a.	Disable Ticket Logon	0
<code>MAX_FAILED_PASSWORD_LOGON_ATTEMPTS</code>	<code>login/fails_to_user_lock</code>	Maximum Number of Failed Attempts	5
<code>MAX_PASSWORD_IDLE_INITIAL</code>	<code>login/password_max_idle_initial</code>	Validity of Unused Initial Passwords	0
<code>MAX_PASSWORD_IDLE_PRODUCTIVE</code>	<code>login/password_max_idle_productive</code>	Validity of Unused Productive Passwords	0
<code>PASSWORD_LOCK_EXPIRATION</code>	<code>login/failed_user_auto_unlock</code>	Automatic Expiration of Password Lock	0
<code>SERVER_LOGON_PRIVILEGE</code>	n.a.	Logon if <code>login/server_logon_restriction=1</code>	0
<code>TENANT_RUNLEVEL_LOGON_PRIVILEGE</code>	n.a.		
Password Change Policies			
<code>MIN_PASSWORD_CHANGE_WAITTIME</code>	<code>login/password_change_waittime</code>	Minimum Wait Time for Password Change	1
<code>MIN_PASSWORD_DIFFERENCE</code>	<code>login/min_password_diff</code>	No. of Different Chars When Changing	1
<code>PASSWORD_CHANGE_FOR_SSO</code>	<code>login/password_change_for_SSO</code>	Password Change Req. for SSO Logons	1
<code>PASSWORD_CHANGE_INTERVAL</code>	<code>login/password_expiration_time</code>	Interval for Regular Password Changes	0
<code>PASSWORD_COMPLIANCE_TO_CURRENT_POLICY</code>	<code>login/password_compliance_to_current_policy</code>	Password Change After Rule Tightening	0
<code>PASSWORD_HISTORY_SIZE</code>	<code>login/password_history_size</code>	Size of the Password History	5
Password Rules			
<code>CHECK_PASSWORD_BLACKLIST</code>	n.a.	Check the Password Blacklist	1
<code>MIN_PASSWORD_DIGITS</code>	<code>login/min_password_digits</code>	Minimum Number of Digits	0
<code>MIN_PASSWORD_LENGTH</code>	<code>login/min_password_lng</code>	Minimum Password Length	6
<code>MIN_PASSWORD_LETTERS</code>	<code>login/min_password_letters</code>	Minimum Number of Letters	0
<code>MIN_PASSWORD_LOWERCASE</code>	<code>login/min_password_lowercase</code>	Minimum Number of Lowercase Letters	0
<code>MIN_PASSWORD_SPECIALS</code>	<code>login/min_password_specials</code>	Minimum Number of Special Characters	0
<code>MIN_PASSWORD_UPPERCASE</code>	<code>login/min_password_uppercase</code>	Minimum Number of Uppercase Letters	0

SAP Security Baseline Template

n.a.	login/password_downwards_compatibility	password downwards compatibility (8 / 40 characters, case-sensitivity)	1
------	--	--	---

PWDPOL-H: Password Policy – SAP HANA settings

Default settings of the password policy provide sufficient protection. Although settings may be changed according to the customers password policy.

Nevertheless there are three settings that must provide a minimum of protection in section password policy of file indexserver.ini:

- minimal_password_length
- maximum_unused_initial_password_lifetime⁴
- force_first_password_change

You can review the settings in the studio at Security → tab 'Password Policy' or with

```
select * from public.m_password_policy
```

The password lifetime must be limited for all users. Exception: Technical users may get an unlimited password lifetime if required.

On a 3-tier scenario typical technical application server users are SAP<SID> and DBACOCKPIT. More users may exist depending on your scenarios.

A list of accounts with unlimited password lifetime can be found with following statement:

```
select user_name, password_change_time from public.users where password_change_time is null and (not user_name = 'SYS' and not user_name like '_SYS_%')
```

If the user SYSTEM is locked and the password stored in a safe place for emergency situations it might be an option to allow an unrestricted password lifetime for SYSTEM as well.

PWDPOL-J: Password Policy – SAP AS Java settings (UME)

Currently there is no additional information for this requirement available.

Related Checks in EWA and SOS

In the **EWA** (EarlyWatch Alert), the check on the minimum password length is included and checks against a minimum length enforcement of at least 8 characters.

In the **SOS** (Security Optimization Service),

- Minimum Password Length (0126)
- Interval for Password Change Is Too Long (0127)

RFCGW: RFC Gateway Security

The RFC Gateway must be configured to restrict access to started and registered RFC servers to an acceptable minimum.

⁴ In HANA Release 1 the parameter maximum_unused_initital_password_lifetime is used (missing "i" in "init(i)al").

As of HANA Release 2 the parameter maximum_unused_initial_password_lifetime is used instead.

SAP Security Baseline Template

RFCGW-A: RFC Gateway Security (part of application server ABAP)

See following notes and blogs before setting profile parameter `gw/acl_mode_proxy = 1` and maintaining the Access Control List file `prxyinfo` (the file name is defined with profile parameter `gw/prxy_info`):

Note [910918](#) - GW: Parameter `gw/prxy_info`

Note [1848930](#) - GW: Strong `gw/prxy_info` check (bit value 128)

Note [3224889](#) - GW: Change of the default settings for `gw/prxy_info` with parameter `gw/acl_mode_proxy`

Blog: [RFC Gateway security, part 4 – prxyinfo ACL](#)

RFCGW-J: RFC Gateway Security (part of application server Java)

Currently there is no additional information for this requirement available.

RFCGW-O: RFC Gateway Security (stand-alone)

Currently there is no additional information for this requirement available.

Related Checks in EWA and SOS

In the **SOS** (Security Optimization Service), the following checks apply

- Gateway Security Properties (SY087)
- Enabling an Initial Security Environment (SY088)
- Gateway Access Control Lists (SY089)
- Remote Monitoring Function for the RFC Gateway Is Not Disabled (0269)
- Permit-all simulation mode is active for the RFC gateway (0273)

SCRIPT: Scripting Protection

SCRIPT-A: Scripting Protection – ABAP

The profile parameter `sapgui/user_scripting` controls the availability of SAP GUI Scripting in an all-or-nothing kind of way. The other parameters could be used to restrict scripting if you cannot omit it for some reasons.

Regarding profile parameter `sapgui/user_scripting_per_user = TRUE` or `FALSE` please note:

Both values are accepted – `TRUE` just adds an additional authorization check for `S_SCR`.

SAP GUI Scripting Security Guide

https://help.sap.com/doc/97d2d0bc2ed248a4a85a0bec608704f8/760.01/en-US/sap_gui_scripting_sec_guide.pdf

SECSTO: Protection of Secure Store

SECSTO-A: Protection of Secure Store – ABAP

Set an individual main key using transaction `SECSTORE` respective report `RSEC_KEY_WIZARD` according to note [1902611](#).

This report shows result of (RFC enabled) function `SECSTORE_KEY_WIZARD_RFC` for `IV_TASKTYPE = G`. If `EF_SECSTORE_FS_KEY_ID` is not empty you are using a specific key. If

SAP Security Baseline Template

EF_SECSTORE_DB_KEYFILE is not empty (and EF_PRIMARY_KEY_HASH is empty) you are using the known default key.

Recommended value of profile parameter rsec/securestorage/keyfile =
\$(DIR_GLOBAL)\$(DIR_SEP)security\$(DIR_SEP)data\$(DIR_SEP)SecStoreDBKey.pse

SECSTO-J: Protection of Secure Store – Java

Currently there is no additional information for this requirement available.

SECUPD: Regular Security Updates

SAP Software on premise has to be updated regularly to the latest version or Support Package Stack at least once a year (refer to <https://support.sap.com/en/my-support/software-downloads/support-package-stacks.html> for further details).

For SAP NetWeaver-based products, SAP provides Security Notes with high or very high priority for the support packages from the last 24 months (refer to <https://support.sap.com/securitynotes> for further details).

If your software is older, Security Notes may not be provided for your software. Moreover, you will miss all security corrections which are only delivered via support packages. Thus, your system may be at risk beyond security maintenance best practices through unpatched software vulnerabilities.

SAP publishes new or updated Security Notes usually on the Patch Day which is the 2nd Tuesday per month. (However, some notes are published on other dates, too.)

A Security Patch Process with clearly defined roles and responsibilities should be defined to identify required Security Notes, to decide about the implementation, and to implement them in a controlled manner.

You find the list of all Security Notes on the SAP Support Portal:

<https://support.sap.com/securitynotes> → Security Notes

This is a filtered list. To show all notes choose function “All Security Notes”

<https://support.sap.com/notes> → Expert Search

Use a filter for “Document Type” = “SAP Security Note”.

You may add another filter for the date range, e.g. to find all Security Notes of a specific patch day. In this case you choose a date range starting one day after the previous patch day until to the specific patch day.

Use application System Recommendations of the SAP Solution Manager to calculate relevant notes per system. This application uses information about installed software component versions, installed support packages or patches and in case of an ABAP system already implemented notes to identify relevant notes.

Limitation: The application does not verify any manual configuration instructions like setting profile parameters or activating switches which might be described in the notes. You have to develop your own reporting infrastructure to analyze required manual configuration settings. Several requirements described in this document refer to such configuration settings.

See <https://support.sap.com/sysrec> for details.

SECUPD-P: Regular Security Updates – BTP

- b) If the Cloud Connector version is outdated, the latest set of important bug fixes and security patches have not been applied and may lead to operational and security issues.
New versions of the Cloud Connector are announced in the [Release Notes of SAP BTP](#). We recommend that Cloud Connector administrators regularly check the release notes for Cloud

SAP Security Baseline Template

Connector updates. The upgrade to the latest version should be conducted in a timely manner. See SAP Help Portal:

- [SAP BTP Connectivity / Cloud Connector – Upgrade](#)
- [SAP BTP Connectivity / Cloud Connector – Release and Maintenance Strategy](#)
- [SAP Development Tools – Cloud Connector](#)

SESS: Session Protection

SESS-J: Session Protection – Java

See <https://help.sap.com/viewer/2f8b1599655d4544a3d9c6d1a9b6546b/7.4.19/en-US/44691ccdce2a3675e10000000a114a6b.html>

SELFRG: No Self-Registration of Users

SELFRG-J: No Self-Registration of Users

The UME parameter `ume.logon.selfreg` is obsolete according to note [2666331](#).

Self-registration is still possible according to the documentation:

Configuring Self-Registration

https://help.sap.com/docs/SAP_NETWEAVER_740/44a42f8a693e4498be42434d28ff3457/440761cea5c610b3e10000000a11466f.html

STDUSR: Standard User

STDUSR-A: Standard User in ABAP

Standard users created by the SAP Solution Manager:

With new installations of the SAP Solution Manager all generated users get specific passwords. However, old installations of the SAP Solution Manager may have generated users with well-known password. See notes [2293011](#) and [2119627](#) for details which list following users:

SOLMAN_BTC, CONTENTSERV, SMD_BI_RFC, SMD_RFC,
SMDAGENT_<SAPSolutionManagerSID>, SMD_ADMIN, SMD_AGT, and additional dialog users
SAPSUPPORT, SOLMAN_ADMIN

Ensure to use a specific password for those users.

Known limitation: You cannot use report RSUSR003 or the SOS or the Configuration Validation to validate these users.

STDUSR-H: Standard Users in HANA

a) The passwords of the `SYSTEM` user must have been changed since the handover of the appliance to the customer.

Information about the `SYSTEM` user can be retrieved with the sql statement:

```
select * from public.users where user_name = 'SYSTEM'
```

Review the field `PASSWORD_CHANGE_TIME`, but be aware that this is not an absolute valid source of information for two reasons:

- If the password live time for the user is disabled, the value of password change time is *null*
- If the password live time was enabled after disabling the value of the password change time is set to the reactivation time

SAP Security Baseline Template

b) Deactivate the `SYSTEM` user. Do not restrict the valid time range of user `SYSTEM`.

Caveat: You must have set up an administration concept and corresponding administrators before doing this!

Procedure: Use the user maintenance user interface or following statement:

```
select user_name, valid_from, valid_until, user_deactivated from  
public.users where user_name = 'SYSTEM'
```

Note: to deactivate the `SYSTEM` user you need to set up an administration concept for the SAP HANA DB including administration users and administration roles. Guidance can be found at following document:

How to Define Standard Roles for SAP HANA Systems

<https://scn.sap.com/docs/DOC-53974>

Related Checks in EWA and SOS

In the **SOS** (Security Optimization Service), the following checks apply

SOS ABAP:

- User SAP* has the default password in some clients (0041)
- Not all profiles are removed from user SAP* (0042)
- User SAP* is neither locked nor expired (0043)
- User SAP* is not assigned to the user group SUPER (0044)
- User SAP* has been deleted at least in one client (0045)
- Usage of the hard-coded user SAP* is not disabled (0046)
- User SAP*'s activities are not logged in the Security Audit Log (0047)
- User DDIC has the default password in some clients (0048)
- User DDIC Is Not Assigned to the User Group SUPER (0049)
- User DDIC's activities are not logged in the Security Audit Log (0050)
- User SAPCPIC has the default password in some clients (0051)
- User SAPCPIC Is Neither Locked nor Expired (0052)
- User SAPCPIC Not Assigned to the Group SUPER (0053)
- User SAPCPIC Has More Authorizations Than Required (0054)
- User SAPCPIC's activities are not logged in the Security Audit Log (0055)
- User EARLYWATCH has the default password (0056)
- User EARLYWATCH Is Not Assigned to User Group SUPER (0058)
- User EARLYWATCH Has More Authorizations Than Required (0059)
- User EARLYWATCH's activities are not logged in the Security Audit Log (0060)
- User TMSADM has the default password in some clients (0063)
- User TMSADM Exists in Clients Other Than Client 000 (0064)
- User TMSADM has more authorizations than required (0065)

SOS HANA:

SAP Security Baseline Template

- Activation Status and Validity of User SYSTEM (HA039)
- Confidentiality of SYSTEM user password (HA065)

TRACES: Critical Data in trace files

Currently there is no additional information for this requirement available.

TRACES-H: Critical Data in trace files – HANA

a) See related notes:

Note [2119087](#) - How-To: Configuring SAP HANA Traces

Note [2486668](#) - How To Disable SQL Trace level ALL_WITH_RESULTS in HANA

TRUST: Trusting relations between systems

Connection between systems may make use of trusting relationships to forward authentication information. There exist many use cases:

- Backend systems trust the Fiori Gateway system
- Managed systems trust the SAP Solution Manager
- Business systems trust the GRC Emergency Access Management system
- Application systems trust the Identification and Authentication systems
- Application systems trust the SAP Web Dispatcher which acts as the TLS endpoint
- ...

TRUST-A: Trusting relations and trusted destinations – ABAP

You find more information here:

Note [3089413](#) - Capture-replay vulnerability in SAP NetWeaver AS for ABAP and ABAP Platform
https://help.sap.com/docs/SUPPORT_CONTENT/security/3362974742.html

USRCHAR: Allowed character sets for user names

USRCHAR-A: Allowed character sets for user names – ABAP

a) Prohibit that user names could contain 'wide' spaces

See note [1731549](#) and

https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbcccf/8a922c9d7bca45c9b29bff3c59b344df.html

USRCTR: User Control of Action

USRCTR-A: User Control of Action – ABAP

a) Profile Parameter `dynp/checkskip1screen` controls GUI shortcut security according to notes [2999707](#), [1399324](#) and [1157137](#).

Profile parameter `dynp/confirmskip1screen = ALL` controls GUI shortcut security according to note [1956086](#))

You can use one of both options to secure GUI shortcuts. Do not activate both options.

Both options require to maintain an allowlist if you do not want to block any GUI shortcut:

SAP Security Baseline Template

- Profile Parameter `dynp/checkskip1screen` → Maintain table view `V_TSTCS` in `SM30`
 - Profile parameter `dynp/confirmskip1screen` → Maintain allowlist `BC_CHECK_EXT_SKIP_FIRST_SCREEN` in transaction `SLDW`
- f) Profile parameter `rdisp/vbdelete` = 0 could lead to problems during system update. Therefore, choosing a value of at least 400 days is preferred.
- g) Most⁵ Switchable authorization check framework (SACF) scenarios should be active in transaction `SACF_COMPARE`. Make sure that users have appropriate authorizations.
- In certain situations, SAP needs to deliver authorization changes for existing functionality. The switchable authorization check framework (SACF) allows the activation of these additional functional authorization checks. If SACF scenarios are not enabled, additional functional authorization checks are not enforced.
- h) All Generic Application Access Rules (SLDW) scenarios should be active in transaction `SLDW_COMPARE`.
- In certain situations, SAP needs to deliver new access rules for existing functionality. The Generic Application Access Rules Framework (SLDW) allows the activation of these additional access rules. If SLDW scenarios are not enabled, additional functional access rules are not enforced.

USRCTR-O: User Control of Action – Others

Permissions of OS user on Windows

If an SAP system is installed on Windows, several users are created on operating system level:

- The user `<sid>adm` is used for administrative purposes on operating system level. It is member of the local Administrators group.
- The user `SAPService<SID>` is the account to run the SAP system. It must not be a member of the local Administrators group.
- The user `sapadm` is the account to run the SAP Host Agent. It must not be a member of the local Administrators group.
- Further users depending on the version of the installation.

Hint: When SAP Host Agent is upgraded to the latest version, the settings for `sapadm` are automatically corrected to be compliant.

[SAP System Security on Windows - SAP Help Portal](#)

Permissions of OS users on Unix/Linux

If an SAP system is installed on Unix/Linux the account `<sid>adm` is used to run the SAP system. The account `<sid>adm` must not have root permissions.

The account `sapadm` is used to run the SAP Host Agent. The account `sapadm` must not have root permissions. The default shell `/bin/false` as defined in `/etc/passwd` of the account `sapadm` must not be changed.

⁵ Following SACF scenarios are not activated by Secure-by-Default in S/4HANA according to the exception list in function `SACF_SET_SBD`: `BC_GENERIC_REPORT_START`, `BC_GENERIC_REPORT_START_BATCH`, `SACF_DEMO_SCENARIO`, `FIN_PARL_ACCTG_LEDGER`.

SAP Security Baseline Template

Hint: When SAP Host Agent is upgraded to the latest version, the settings for `sapadm` are automatically corrected to be compliant.

[SAP System Security Under UNIX/LINUX - SAP Help Portal](#)

Secure shares / exports

Shares / NFS exports must not be accessible by everyone / all domain users. Shares / NFS exports must only be accessible from dedicated systems and/or with dedicated accounts.

Shares used by the SAP System (e.g. `saploc`, `sapmnt`) must only be accessible for SAP system users and dedicated admin accounts (e.g. `<sid>adm`).

File permissions for `/usr/sap` must be only granted to SAP admins and SAP technical users (e.g. `<sid>adm`).

USRTYP: Types of Users

All users should be part of the customers' user base and no external user should have access to the global account.

USRTYP-P: Types of Users in BTP

Platform users are usually developers, administrators or operators who deploy, administer, and troubleshoot applications and services on SAP BTP.

We recommend that you configure the Identity Authentication service as the custom identity provider and connect Identity Authentication to your own corporate identity provider.

See SAP Help Portal: [Platform Users](#)

Business users use the applications that are deployed to SAP BTP. For example, the end users of SaaS apps or services, such as SAP Workflow service or SAP Cloud Integration, or end users of your custom applications are business users.

We recommend that you configure the Identity Authentication service as the identity provider and connect Identity Authentication to your own corporate identity provider.

See SAP Help Portal: [Business Users](#)

Configuring your own managed identity provider for BTP users allows you to enforce custom security configurations like two-factor authentication (2FA), password policies, administrative access (lock users etc.) and to have full control over the userbase.

SAP Security Baseline Template

3.2 Configuration Stores in SAP Solution Manager

The application Configuration Validation in the SAP Solution Manager supports landscape-wide verification of SAP systems for compliance to technical requirements. To ease the implementation of Configuration Validation for an SAP Security Baseline, SAP additionally provides uploadable files respective transport files to configure Configuration Validation which match to SAP Security Baseline Template. These files together with a description on how to utilize them and a corresponding documentation of the uploadable content are available on the SAP Support Portal in <https://support.sap.com/sos> → Media Library → SAP Security Baseline Template.

Of course, any changes which you may apply to these requirements when creating your specific SAP Security Baseline need then to be applied to the configuration of Configuration Validation as well.

The following chapters list the target systems provided by this package together with the names of the configuration stores containing the relevant configuration items.

3.2.1 Configuration Stores ABAP

Requirement	Target System(s)	Configuration Store	Configuration Item
AUDIT-A	2AAUDIT	ABAP_INSTANCE_PAHI	Profile Parameters
		AUDIT_CONFIGURATION	Audit configuration
AUTHASSIGN-A		PRGN_CUST (This store is only available in FRUN)	Customizing
CHANGE-A	1ACHANGE	GLOBAL	Global Settings
		CLIENTS	Client Change Option
	2ACHANGE	ABAP_INSTANCE_PAHI	Profile Parameters
		TRANSPORT_TOOL	Transport Parameters
	3ACHANGE	TRANSPORT_TOOL	Transport Parameters
CRITAU-A	1ACRITA	AUTH_PROFILE_USER	Users having critical authorizations
		AUTH_PROFILE_USER_CHANGE_DOC	Users having critical authorizations
	1ACRITB	AUTH_ROLE_USER	Users having critical roles
		AUTH_PROFILE_USER	Users having critical authorization profiles
		AUTH_PROFILE_USER_CHANGE_DOC	Users having critical authorization profiles

SAP Security Baseline Template

Requirement	Target System(s)	Configuration Store	Configuration Item
	1ACRITC	AUTH_COMB_CHECK_ROLE	Roles having critical authorizations
		AUTH_COMB_CHECK_USER	Users having critical authorizations
	2ACRITD	TDDAT	Table authorization groups
		AUTH_COMB_CHECK_USER	Users having critical authorizations
DISCL-A	2ADISCL	ABAP_INSTANCE_PAHI	Profile Parameters
FILE-A	2AFILE	ABAP_INSTANCE_PAHI	Profile Parameters
	3AFILE	AUTH_COMB_CHECK_USER	Users having critical authorizations
		AUTH_COMB_CHECK_ROLE	Roles having critical authorizations
		SPTH (This store is only available in FRUN)	Secured file paths
MSGSRV-A	1AMSGSRV	ABAP_INSTANCE_PAHI	Profile Parameters
		MS_SECINFO	Access Control List
	2AMSGSRV	ABAP_INSTANCE_PAHI	Profile Parameters
NETCF-A	2ANETCF	ABAP_INSTANCE_PAHI	Profile Parameters
		SICF_SERVICES	SICF Services
		ABAP_UCON_HTTP_WHITE_LIST (This store is only available in FRUN)	HTTP Allow List
NETENC-A	1ANETENC	ABAP_INSTANCE_PAHI	Profile Parameters
	2ANETENC	ABAP_INSTANCE_PAHI	Profile Parameters
	3ANETENC	ABAP_INSTANCE_PAHI	Profile Parameters
OBSCNT-A	2AOBSCNT	CLIENTS	Clients
PWDPOL-A	1APWDPOL	ABAP_INSTANCE_PAHI	Profile Parameters
		AUTH_SECURITY_POLICY	Security Policy
	2APWDPOL	ABAP_INSTANCE_PAHI	Profile Parameters
		AUTH_SECURITY_POLICY	Security Policy
		USER_PASSWD_HASH_USAGE	Usage of hash method for passwords

SAP Security Baseline Template

Requirement	Target System(s)	Configuration Store	Configuration Item
	3APWDPOL	ABAP_INSTANCE_PAHI	Profile Parameters
		AUTH_SECURITY_POLICY	Security Policy
RFCGW-A	1ARFCGW	ABAP_INSTANCE_PAHI	Profile Parameters
		GW_SECINFO	Access Control List
		GW_REGINFO	Access Control List
	3ARFCGW	ABAP_INSTANCE_PAHI	Profile Parameters
SCRIPT-A	3ASCRIP	ABAP_INSTANCE_PAHI	Profile Parameters
SECSTO-A		ABAP_SECSTORE_INFO (This store is only available in FRUN)	Customizing
SECUPD-A	1ASECUP	Various	Samples
STDUSR-A	1ASTDUSR	STANDARD_USERS	Standard Users
		ABAP_INSTANCE_PAHI	Profile Parameters
SSO-A	1ASSO	ABAP_INSTANCE_PAHI	Profile Parameters
TRUST-A	1ATRUST	RFCSYSACL	Permitted trusted systems
	2ATRUST	ABAP_INSTANCE_PAHI	Profile Parameters
	3ATRUST	ABAP_INSTANCE_PAHI	Profile Parameters
USRCTR-A	2AUSRCTR	ABAP_INSTANCE_PAHI	Profile Parameters
		ABAP_SACF_INFO (This store is only available in FRUN)	Switchable Authorizations
		ABAP_SLDW_INFO (This store is only available in FRUN)	Switchable Access Control Lists
USRCHAR-A		PRGN_CUST (This store is only available in FRUN)	Customizing
USRTYP-A		PRGN_CUST (This store is only available in FRUN)	Customizing

3.2.2 Configuration Stores Java

Requirement	Target System(s)	Configuration Store	Configuration Item
AUDIT-J	3JAUDIT	xmlhardener_srv	
CRITAU-J	2JCRITAU	AUTH_ROLE_USER	Role assignments (double stack ABAP)
DISCL-J	2JDISCL	http	Server Header Settings
MSGSRV-J	1JMSGSRV	Parameters	Parameters

SAP Security Baseline Template

Requirement	Target System(s)	Configuration Store	Configuration Item
	2JMSGSRV	Parameters	Parameters
NOTEST-J	1JNOTEST	servlet_jsp	Java property
PWDPOL-J	1JPWDPOL	com.sap.security.core.ume.service	User Management settings
	3JPWDPOL	com.sap.security.core.ume.service	User Management settings
RFCGW-J	1JRFCGW	Parameters	Profile Parameters
	3JRFCGW	Parameters	Profile Parameters
SECUPD-J	1JSECUP	Various	Samples
SEIFRG-J	2JSEIFRG	com.sap.security.core.ume.service	User Management settings
SESS-J	2JSESS	http	Session parameters
SSO-J	3JSSO	com.sap.security.core.ume.service	User Management settings

3.2.3 Configuration Stores HANA

Requirement	Target System(s)	Configuration Store	Configuration Item
AUDIT-H	1HAUDIT	HDB_PARAMETER	HANA settings
	2HAUDIT	HDB_PARAMETER	HANA settings
CRITAU-H	1HCRITAU	SPECIAL_PRIVILIGES	HANA privileges
NETCF-H	1HNETCF		
OBSCNT-H	./.		
PWDPOL-H	1HPWDPOL	HDB_PARAMETER	HANA settings
	2HPWDPOL	HDB_PARAMETER	HANA settings
	3HPWDPOL	HDB_PARAMETER	HANA settings
SECUPD-H	1HSECUP	Various	Samples
STDUSR-H	2HSTDUSR	PUBLIC_USERS	Standard Users
TRACES-H	1HTRACES	HDB_PARAMETER	HANA settings

3.2.4 Configuration Stores Others

Requirement	Target System(s)	Configuration Store	Configuration Item
DISCL-O	./.		
NETENC-O	./.		
RFCGW-O	./.		

SAP Security Baseline Template

Requirement	Target System(s)	Configuration Store	Configuration Item
SECUPD-O	./.		

3.2.5 Configuration Stores for Security Notes

Requirement	Target System	Configuration Store
SECUPD-A Regular Security Updates	N0510007 Note 510007 - Setting up SSL on AS ABAP	ABAP_INSTANCE_PAHI
		ABAP_INSTANCE_PAHI_ENH
		CRYPTOLIB
		PSE_CERT
	N1322944 Note 1322944 - ABAP: HTTP security session	ABAP_INSTANCE_PAHI
		SESSION_MANAGEMENT
	N2065596 Note 2065596 - Restricting logons to server	ABAP_INSTANCE_PAHI
		AUTH_SECURITY_POLICY
		SAP_KERNEL
		SECURITY_POLICY_USAGE
	N2288631 Note 2288631 - CommonCryptoLib	CRYPTOLIB
	N2449757 Note 2449757 - Add.auth.check in Trusted RFC	ABAP_INSTANCE_PAHI
		SAP_KERNEL
	N2562089 Note 2562089 - Directory Traversal vulnerability	ABAP_INSTANCE_PAHI
		ABAP_NOTES
	N2562127 Note 2562127 - R/3 Support Connection SNC / SSO	ABAP_INSTANCE_PAHI
		PSE_CERT
	N2671160 Note 2671160 - Missing input validation in CTS	SAP_KERNEL
		TRANSPORT_TOOL
	N2934135 Note 2934135 - LM Configuration Wizard	J2EE_COMP_SPLEVEL

3.3 Security Scenario of Focus Insight

How to use the Security Scenario of the Tactical Dashboard of Focus Insight:

SAP Security Baseline Template

Focused Insights – Security Scenario

<https://wiki.scn.sap.com/wiki/display/SM/Security+scenario%3A+Security+Notes+Validation+respective>

<https://wiki.scn.sap.com/wiki/display/SM/Security+scenario%3A+Security+Notes+Validation?preview=/541823302/547425569/Security%20Scenario%20Configuration%20Validation%20for%20Tactical%20Dashboard%207.2.pdf>

3.4 Policies for Configuration and Security Analytics (CSA) in SAP Focused Run (FRUN)

You find the Policies for this Security Baseline on GitHub:

<https://github.com/SAP-samples/frun-csa-policies-best-practices>

The validation engine of Configuration and Security Analytics is running directly on SAP HANA database level. It is basically using HANA SQL as described in the [SAP HANA SQL and System Views Reference](#). However, not all features are supported. The actual SQL used for validations is generated automatically based on the XML coding of a policy.

The following page provides an overview on syntax rules, common check types and useful best practices for creating policy content:

<https://support.sap.com/en/alm/sap-focused-run/expert-portal/configuration-and-security-analytics/syntax-rules-and-policy-check-examples.html>

3.5 Secure by Default settings in S/4HANA and BW/4HANA

From SAP S/4HANA 1909 onwards and SAP BW/4HANA 2021 onwards, new installations (with SWPM), system copies (with SWPM) and system conversions from SAP ERP to SAP S/4HANA (with SUM) will automatically receive the recommended security settings. An opt-out is possible for the security relevant profile parameters, but not recommended from SAP side.

In SAP S/4HANA and SAP BW/4HANA upgrades (with SUM), security settings are not adjusted automatically. In some cases, preparations are necessary before configurations / parameters can be switched to secure values in upgraded systems. That's why configurations / parameters are not changed during the upgrade process. Though it's recommended to also apply the updated security settings in system which have been upgraded from older SAP S/4HANA and BW/4HANA releases.

After the upgrade is completed, use the report `RSPFRECOMMENDED` to compare the actual system values with the recommended security settings for security relevant profile parameters. (You find this report in transaction `RZ11` at menu item "Goto" → "All recommended values", too.)

For all parameters deviating from the recommended value, carry out in detail:

- Review the deviations
- Understand the impact of the profile parameters (refer to the attached spreadsheet)
- Execute the necessary preparations
- Adjust the profile parameters to the recommended security setting after preparations have been executed.

For more details see following notes:

Note [2713544](#) - New security settings during conversion to SAP S/4HANA 1909 (and later) and SAP BW/4HANA 2021 (and later) with SUM 2.0

SAP Security Baseline Template

Note [2714839](#) - New security settings for SAP S/4HANA 1909 (and later) and SAP BW/4HANA 2021 installations and system copies using SL Toolset 1.0

Note [2926224](#) - Collection Note: New security settings for SAP S/4HANA and SAP BW/4HANA using SL Toolset and SUM

Note [2975959](#) - Security settings during upgrade to SAP S/4HANA 2020 (and later) with SUM 2.0 SP09 (and later) or SAP BW/4HANA 2021 (and later) with SUM 2.0 SP10

3.5.1 New secure default settings in S/4HANA 2023 and BW/4HANA 2023

- Restricted character sets for user name
Customizing BNAME_RESTRICT = XXX in table PRGN_CUST
Note [1731549](#) and
https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbccc/f8a922c9d7bca45c9b29bff3c59b344df.html
- No direct user assignments while exporting transports
Customizing US_ASGM_TRANSPORT = NO in table PRGN_CUST
Note [1723881](#) and
https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbccc/f8a922c9d7bca45c9b29bff3c59b344df.html
- No direct user assignments while importing transports
Customizing USER_REL_IMPORT = NO in table PRGN_CUST
Note [571276](#) and
https://help.sap.com/docs/ABAP_PLATFORM_NEW/c6e6d078ab99452db94ed7b3b7bbccc/f6d7c8cfd410ea040aadf92e1f78107a4.html
- Profile parameter rfc/allowoldticket4tt = no
Note [3157268](#) and
https://help.sap.com/docs/SUPPORT_CONTENT/security/3362974742.html
- HANA data at rest encryption is enabled for S/4HANA HANA systems
Note [2159014](#) and
https://help.sap.com/docs/SAP_HANA_PLATFORM/b3ee5778bc2e4a089d3299b82ec762a7/b30fda1483b34628802a8d62bd5d39df.html

3.5.2 New secure default settings in S/4HANA 2022 and BW/4HANA 2022

- Profile parameter gw/acl_mode_proxy = 1
Note [3224889](#)
- Profile parameter login/ticket_only_by_https = 1
Note [1531399](#)
- Profile parameter ssl/ciphersuites =
545:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH
Note [3198351](#)
- Profile parameter rfc/log/active = 1
Profile parameter icf/log/active = 1
SAP Help
https://help.sap.com/docs/ABAP_PLATFORM_NEW/1ca554ffe75a4d44a7bb882b5454236f/47ee08e9109643c6a1d92397d12eb270.html
- Customizing REF_USER_CHECK = E in table PRGN_CUST
Note [513694](#)

SAP Security Baseline Template

- Profile parameters for host agent profile:
ssl/ciphersuites = 545:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH
ssl/client_ciphersuites = 150:PFS:HIGH::EC_X25519:EC_P256:EC_HIGH
ssl/client_sni_enabled = TRUE
Note [3213711](#)

3.5.3 New secure default settings in S/4HANA 2021 and BW/4HANA 2021

- Profile parameter `rec/client = ALL`
Note [3093760](#)
- Transport parameter `RECCLIENT = ALL`
Note [84052](#)
- Transport parameter `TLOGOCHECK = TRUE`
Note [2671160](#)
- Transport parameter `VERS_AT_IMP = ALWAYS`
Note [1784800](#)
- UCON HTTP allowlist for all relative path for 01 Trusted Network Zone and 03 CSS Style Sheet and active check for 02 Clickjacking Framing Protection
Note [3083852](#)
- Enable authorization object `S_START` checks for Web Dynpro Application Configuration (WDCA) and Web Dynpro Applications (WDYA)
Note [3064888](#)
- All `SLDW` scenarios are set to productive scenario as shipped by SAP. In certain cases, additional activation of allowlist checks might be necessary (status of check is not active)
Note [1922712](#)
- HANA auditing is enabled in TenantDB and a recommended set of HANA audit policies is configured in TenantDB
Note [3016478](#)

3.5.4 New secure default settings in S/4HANA 2020

See note [2975959](#) - Security settings during upgrade to SAP S/4HANA 2020 (and later) with SUM 2.0 SP09 (and later) or SAP BW/4HANA 2021 (and later) with SUM 2.0 SP10

- Profile parameter `icf/reject_expired_passwd = 1`
Note [1042274](#)
- Profile parameter `login/password_compliance_to_current_policy = 1`
Note [862989](#)
- Profile parameter `login/password_max_idle_initial = 7`
Note [862989](#)
- Profile parameter `login/password_max_idle_productive = 180`
Note [862989](#)
- Profile parameter `login/show_detailed_errors = 0`
Note [2001962](#)
- Profile parameter `system/secure_communication = ON`
Note [2040644](#)

SAP Security Baseline Template

- All scenarios in Switchable Authorization Check Framework (SACF) are set to productive scenario with active checks.
Note [2958356](#)

3.5.5 New secure default settings in S/4HANA 1909

See note [2714839](#) - New security settings for SAP S/4HANA 1909 (and later) and SAP BW/4HANA 2021 installations and system copies using SL Toolset 1.0

- Profile parameter `auth/check/calltransaction = 3`
Note [515130](#)
- Profile parameter `auth/object_disabling_active = N`
Note [2926224](#)
- Profile parameter `auth/rfc_authority_check = 6`
Note [2216306](#)
- Profile parameter `gw/reg_no_conn_info = 255`
Note [2776748](#)
- Profile parameter `gw/rem_start = DISABLED`
Note [2776748](#)
- Profile parameter `icf/set_HTTPonly_flag_on_cookies = 0`
Note [1277022](#)
- Profile parameter `icm/HTTP/logging_0 =`
`PREFIX=/, LOGFILE=http_%y_%m.log, MAXFILES=2, MAXSIZEKB=50000, SWITCHTF`
`=month, LOGFORMAT=%t %a %u1 \"%r\" %s %b %Lms %{Host}i %w1 %w2`
Note [2788140](#)
- Profile parameter `icm/HTTP/logging_client_0 =`
`PREFIX=/, LOGFILE=http_client_%y_%m.log, MAXFILES=2, MAXSIZEKB=50000, S`
`WITCHTF=month, LOGFORMAT=%t %a %u1 \"%r\" %s %b %Lms %{Host}i`
Note [2788140](#)
- Profile parameter `icm/security_log =`
`LOGFILE=dev_icm_sec_%y_%m, LEVEL=3, MAXFILES=2, MAXSIZEKB=50000, SWITCH`
`TF=month`
Note [2788140](#)
- Profile parameter `login/disable_cplic = 1`
Note [2926224](#)
- Profile parameter `login/password_downwards_compatibility = 0`
Note [1023437](#)
- Profile parameter `login/password_hash_algorithm = encoding=RFC2307,`
`algorithm=iSSHA-512, iterations=15000, saltsize=256`
Note [2140269](#)
- Profile parameter `ms/HTTP/logging_0 = PREFIX=/, LOGFILE=$(DIR_LOGGING)/ms-`
`http-%y-%m-%d.log%o, MAXFILES=7, MAXSIZEKB=10000, SWITCHTF=day, LOGFORM`
`AT=%t %a %u %r %s %b %{Host}i`
Note [2794817](#)
- Profile parameter `ms/http_logging = 1`
Note [2794817](#)

SAP Security Baseline Template

- Profile parameter `rdisp/gui_auto_logout = 3600` (or 1H)
(no note)
- Profile parameter `rdisp/vbdelete = 0`
Note [2441606](#)
- Profile parameter `rfc/callback_security_method = 3`
Note [2678501](#)
- Profile parameter `rfc/reject_expired_passwd = 1`
Note [2579165](#)
- Profile parameter `wdisp/add_xforwardedfor_header = TRUE`
Note [2788140](#)
- The Security Audit Log is configured using the recommended filter settings as described in following notes:
Note [2676384](#) - Best practice configuration of the Security Audit Log
Note [2838480](#) - SAL | Secure by default

3.6 Security Parameters & Hardening requirements in SAP Enterprise Cloud Services (ECS)

The notes [3250501](#) (ABAP), [3480723](#) (HANA) and [3381209](#) (Java) show all security compliant settings for systems of ECS managed (including CDC), premium suppliers and RISE partners based on security hardening requirements and best practices.

- Note [3250501](#) - Information on mandatory Security Parameters & Hardening requirements for ABAP systems in SAP Enterprise Cloud Services (ECS)
- Note [3480723](#) - Information on mandatory Security Parameters & Hardening requirements for SAP HANA databases in SAP Enterprise Cloud Services (ECS)
- Note [3381209](#) - Information on mandatory Security Parameters & Hardening requirements for JAVA systems in SAP Enterprise Cloud Services

All these parameters/configuration settings are implemented as part of ECS system builds.

It is mandatory for all ECS customers to adhere the parameters/configuration settings in all ABAP and Java systems. The security parameters must be set in the default profile (DEFAULT.PFL).

In case of questions please contact your ECS Client Delivery Manager (CDM) / Technical Service Manager (TSM) / Cloud Architecture & Advisory (CAA) / digital Customer Engagement Manager (dCEM).

Information given in these notes are subject to change based on security hardening requirements.

3.6.1 New/updated secure default settings in ECS Note [3250501](#)

With version 32 from 05.06.2025 you find several new or updated entries about security relevant profile parameters:

Parameter Name	ECS standard	Description
<code>auth/no_check_in_some_cases</code>	Y	Activate the Profile Generator and the application-specific disabling of authorization checks

SAP Security Baseline Template

Parameter Name	ECS standard	Description
abap/ext_debugging_possible	2	This parameter controls whether external debugging is permitted in an ABAP system.
auth/check/calltransaction	3	Behaviour of Authority-Check during Call Transaction
auth/rfc_authority_check	1 → 6	Controls the behavior of enforced authentication and authorization checks when RFC function modules are called from remote.
dba/dba/ccms_maintenance	1	To prevent unauthorised access and maintenance actions in DBA Cockpit
dba/dba/ccms_security_level	1	Only allows authorised users with the required roles can execute CCMS DBA functions.
gw/acl_mode_proxy	1	The system enforces ACL rules for proxy connections based on the settings in secinfo and reginfo files. This is the recommended setting for enhanced security available as of Kernel 7.89
gw/rem_start	DISABLED	This setting specifies with which method an RFC server might be started on OS level from an external endpoint.
icf/reject_expired_passwd	1	Controls whether logon with expired or initial password via HTTP/S is allowed or not. If not set to 1, users with an expired password are able to remotely call SICF services.
login/disable_cplic	1	Disable incoming connections of the type CPIC Communications
login/show_detailed_errors	0	Controls whether detailed error messages are displayed for failed logon attempts. If not set to 0, information are provided about the existence of a user.
rfc/allowoldticket4tt	no	Controls whether old login tickets are accepted in client / server calls for trusted / trusting connections
rfc/callback_security_method	3	This applies the strictest security policy for RFC callbacks, ensuring maximum protection against unauthorized executions.
rfc/reject_expired_passwd	1	Controls whether logon with expired or initial password via RFC is allowed or not
rdisp/TRACE_HIDE_SEC_DATA	ON	Disable sensitive and critical information from being displayed in the traces
sapgui/user_scripting	FALSE	This parameter controls whether SAP GUI Scripting is enabled
snc/permit_insecure_start	1 → 0	Permission to start insecure programs when SNC is enabled

3.7 Recommended Security Configurations for SAP Cloud Services

You find the related "Recommended Security Configurations for SAP Cloud Services" on My Trust Center at [Tools & Documentation](#). This is the landing page for various BTP products/services:

[Recommended Security Configuration for SAP Cloud Services](#)

- [SAP Business Technology Platform](#)

SAP Security Baseline Template

- [SAP S/4 HANA Cloud](#)
- [SAP SuccessFactors](#)
- [SAP Ariba](#)
- [SAP Concur](#)
- [SAP Fieldglass](#)
- [SAP Commissions](#) (SAP SuccessFactors Incentive Management)
- [SAP Analytics Cloud](#)
- [SAP Integrated Business Planning \(SAP IBP\)](#)
- [SAP Cloud for Customer](#)
- [SAP Data Intelligence](#)
- SAP Configure Price Quote (SAP CPQ)

For [SAP Business Technology Platform](#) you find recommendations for various components:

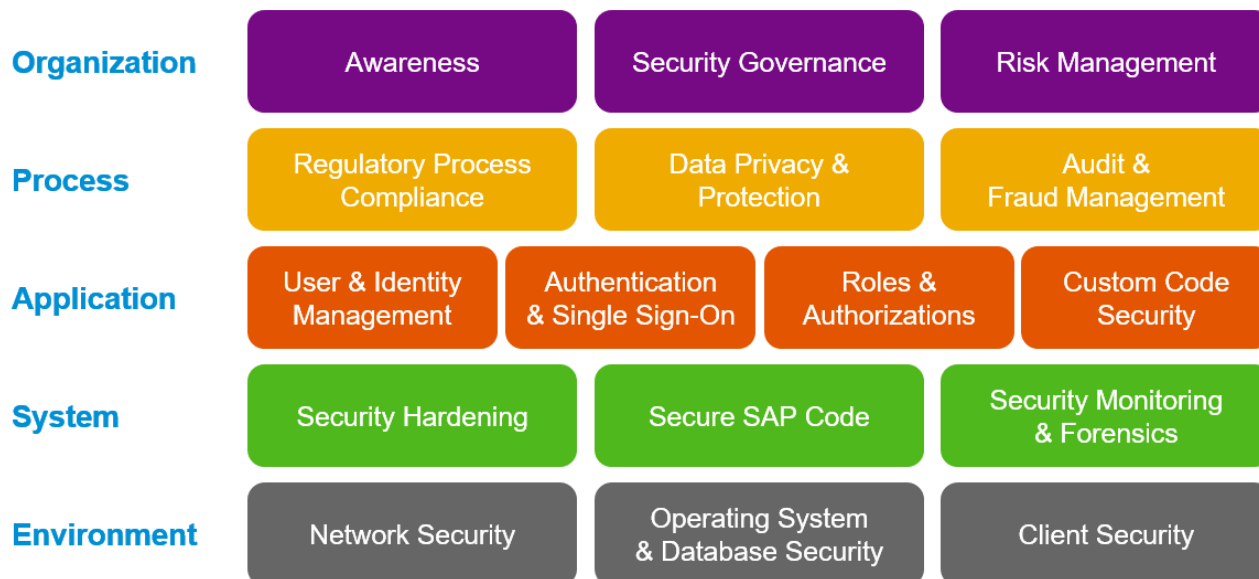
BTP-ALS	Application Logging Service
BTP-ANS	SAP Alert Notification service
BTP-APR	Application Router
BTP-APS	Automation Pilot
BTP-AUD	SAP Audit Log service
BTP-BAS	SAP Business Application Studio
BTP-BRC	Business Rules Capability
BTP-CAS	Content Agent Service
BTP-CLS	Cloud Logging
BTP-CPS	SAP Cloud Portal service
BTP-CPT	SAP BTP cockpit
BTP-CRS	Credential Store
BTP-DES	SAP Destination service
BTP-DOM	Custom Domain Service
BTP-DPI	Data Privacy Integration
BTP-DRM	Data Retention Manager
BTP-ELM	Edge Lifecycle Management
BTP-HDB	SAP HANA Cloud, SAP HANA Database
BTP-HDL	SAP HANA Cloud, Data Lake
BTP-HTM	HTML5 Application Repository Service
BTP-IAS	Identity Authentication
BTP-JSS	Job Scheduling Service
BTP-LMC	SAP Landscape Management Cloud
BTP-MOB	Mobile Services

SAP Security Baseline Template

BTP-MWS	Malware Scanning
BTP-OCS	Open Connectors
BTP-OSS	Object Store
BTP-PDM	Personal Data Manager
BTP-PVC	Process Visibility Capability
BTP-RPA	SAP Intelligent Robotic Process Automation
BTP-SCC	Cloud Connector
BTP-SLS	Secure Login Service
BTP-STC	SAP Task Center
BTP-STR	SAP Start
BTP-TMS	Cloud Transport Management
BTP-UAA	Authorization and Trust Management Service
BTP-WFM	Workflow Management
BTP-WZS	SAP Build Work Zone, standard edition

SAP Security Baseline Template

4 Appendix: SAP Secure Operations Map



4.1 Environment

The “Environment” layer looks at the non-SAP technical environment of SAP cloud offerings, solutions and systems.

4.1.1 Network Security

It is important to have additional protection and monitoring mechanisms embedded into the underlying network infrastructure. Potential attacks need to be countered already through zoning concepts and network components like routers, firewalls or web application filters. Security-critical activities need to be monitored and countered by intrusion detection and prevention systems.

Note that communication security measures in SAP offerings and solutions as well as SAP infrastructure components like SAProuter or SAP Cloud Connector are not part of this block. They are handled in “Security Hardening” (e.g. SAP Cloud Connector, SAProuter), “Authentication & Single Sign-On” (e.g. RFC Gateway, SNC, TLS) or “Roles & Authorizations”.

4.1.2 Operating System & Database Security

When OS and DB are insufficiently configured or users are able to bypass access controls at that level, the protection of applications running on top is at risk. Corresponding security controls in focus include file system level permissions, database user security, tenant separation or data-at-rest encryption methods.

Note that databases from SAP are not part of this building block. They are addressed as specific projections on the Secure Operations Map, as several buildings apply with more details and SAP-specific content.

4.1.3 Client Security

Adversaries may attack client systems to get an entry point, inject bogus data in the traffic or subject the client to weird behavior, if not properly protected. This building block is about client side controls such as secure maintenance, configuration, control and monitoring of the client or execution rules for browsers.

SAP clients like SAPGUI or SAP Business Client are not considered here but in the “Security Hardening” building block.

SAP Security Baseline Template

4.2 System

The “System” layer addresses the SAP platform layer which provides the foundation for all applications operated upon it. The integrity and robustness of this platform is key to ensure that application layer controls (e.g. the authorization systems) cannot be circumvented by lower level vulnerabilities (e.g. SQL injections made possible via insecure code).

4.2.1 Security Hardening

Security Hardening foremost deals with suitable secure settings of relevant system parameters and other configurations.

It also includes activation of security features and functionalities, which may be switched off initially for backward compatibility and migration purposes or which need specific setup and configuration (e.g. UCON)

It also includes hardening of SAP frontend components like SAPGUI or SAP Business Client and of SAP infrastructure components like SAProuter or SAP Cloud Connector.

4.2.2 Secure SAP Code

SAP is continuously doing a high investment to develop and deliver secure code to its customers. Nevertheless, security updates for already delivered code are required regularly due to new attacks and newly identified vulnerabilities.

SAP provides these security updates to its customers via Support Packages / Releases and via SAP Security Notes – published monthly on the SAP Security Patch Day.

Customers need to establish a corresponding Security Maintenance process to ensure a regular and suitable consumption of these security updates.

4.2.3 Security Monitoring & Forensics

With today’s powerful attacks and complex landscapes, proactive security is absolutely required but not sufficient. It needs to be enhanced by reactive security mechanisms, which are able to identify security weaknesses and breaches and thus allow to properly counter them. This includes review and validation activities as well as life monitoring of system operations and triggering of appropriate countermeasures in case of an attack or suspicious system behaviors.

Logs and support are also required for forensics in retrospect of identified or suspected attacks. Also, this needs preparation. If one only starts to look for evidence, when something seems to have happened, it may be too late to activate what would have been required to have this evidence.

4.3 Application

The “Application” layer is about controls that are available in SAP standard applications and non-standard applications built by customers. Here, protective measures are discussed on users and privileges level as well as proper application design.

4.3.1 User & Identity Management

This building block includes the lifecycle management of user accounts in systems and landscapes, proper provisioning, maintenance and revocation, including the approval, assignment and revocation of authorizations to/from specific users. Technical and emergency users are handled here as well as the topic of federation in hybrid environments.

Authorization design, role building and handling of Segregation of Duties are not handled here but in “Roles & Authorizations”.

SAP Security Baseline Template

4.3.2 Authentication and Single Sign-On

Authentication deals with the verification of the true identity of a claimed user. It may be as simple as a password, may include multi-factor mechanisms and may also deal with trusted system connections in which one system relies on the correct authentication by another system.

Single Sign-On establishes an infrastructure, in which a user authenticates himself once in a landscape to then get access to several systems without the need for repeated additional authentication.

As communication security mechanisms like TLS for http-based connections or SNC for RFC connections support the authentic communication between systems and with clients, these mechanisms are included here as well.

4.3.3 Roles & Authorizations

This building block is about everything around roles and authorizations, including the proper definition, distribution and maintenance of authorizations as well as the alignment and combination of roles to business roles across systems in hybrid landscapes. Control of compliance and Segregation of Duties is also covered here.

The assignment and revocation of roles to/for specific users is not handled here but in “User & Identity Management”.

4.3.4 Custom Code Security

The first step in Custom Code Security is proper Custom Code Management: Unnecessary custom code should be removed, required custom code should be maintained in a proper Custom Code Lifecycle Management.

Custom Code Lifecycle Management should cover the whole lifecycle from secure architecture & design via secure development – including but not restricted to the use of code security scanners – up to secure deployment, security maintenance and finally custom code retirement.

4.4 Process

The “Process” layer extends the pure security view with compliance aspects. While security focuses on operating robust SAP applications preventing intentional and unintentional malfunctions and compromise of confidentiality, regulatory compliance deals with the correct behavior of applications with regards to policies and legal demands coming from the various jurisdictions SAP systems are operated in.

4.4.1 Regulatory Process Compliance

In this building block, application functions are considered for their potential capabilities to significantly violate legal requirements when not used properly. Additional controls are then investigated that help keep the risk of such violations under control – prominent examples are mechanisms such as double invoice checks or special tax statement control. Typical regulation that is addressed by such procedures is HIPAA, Basel II+III or SoX, just to name a few.

4.4.2 Data Privacy & Protection

The topics in this building block focus on proper handling and protection mechanisms applicable directly to data belonging to individuals that are specifically protected by newer DPP legislation such as the European GDPR and similar requirements that demand capabilities such as blocking & deletion, consent management, right of access and validation etc.

Even though such mechanisms are not solely related to DPP demands, this building block also includes strong confidentiality measures like field tokenizing or encryption at rest.

SAP Security Baseline Template

4.4.3 Audit & Fraud Management

While regulation must be followed for legal reasons, company often require additional capabilities to detect fraudulent behavior and make sure the controls in place are working effectively. This building block discusses solutions that allow auditing and fraud detection to run smoothly and provide correct data on the covered applications.

Similar to the “Environment” layer, this “Organization” layer is also important to set the environment for SAP systems and SAP cloud solutions. It sets the stage and gives needs and requirements as input to be considered.

4.5 Organization

4.5.1 Awareness

General security awareness is an important pre-condition to achieve security. Not everyone has to be a security expert – but everyone needs to contribute on his part and also needs to identify when security expertise should be called. Ignoring or even countering or circumventing security regulations and mechanisms can endanger a whole landscape. “Awareness” thus also is directly linked to user-friendliness and ease of handling of any security mechanisms or configuration.

4.5.2 Security Governance

Security Governance addresses everything regarding general organization, procedures and regulations including those, which may directly or indirectly impact the setup, configuration, integration and operation of SAP cloud solutions, systems and landscapes.

4.5.3 Risk Management

This comprises all elements on identifying, handling, mitigating and resolving risks including services or SAP solutions in this area.

SAP Security Baseline Template

5 Appendix: References + Links whitepapers / best practices

- [1] [SAP Homepage](#) [publicly available]
- [2] [SAP Help Portal](#) [publicly available]
- [3] [SAP Support Portal](#) ["S-User" ID and Password required]
- [4] [SAP Security](#)
- [5] → Security in Detail → SAP Security Guides [SAP notes on Support Portal](#) ["S-User" ID and Password required]
- [6] [SAP Community Network](#) [publicly available]
- [7] RFC Gateway Security
SAP Note [1036936](#) - Security Note: External RFC Server
The following SAP notes provide additional information to the above mentioned Security Guides in case that the configuration does not exist:
SAP Note [64016](#) - Using the SAP Gateway monitor GWMON
SAP Note [110612](#) - Using the `secinfo` file (gateway ACL)
SAP Note [618516](#) - Security-related enhancement of RFCEXEC program
SAP Note [866732](#) - Security check when executing external commands/programs (2)
SAP Note [910918](#) - GW: Parameter `gw/prxy_info`
SAP Note [1298433](#) - Bypassing security in `reginfo` & `secinfo` (bit value 1)
SAP Note [1434117](#) - Bypassing `sec_info` without `reg_info` (bit value 2)
SAP Note [1465129](#) - CANCEL registered programs (bit value 4)
SAP Note [1473017](#) - Uppercase/lowercase in the files `reg_info` and `sec_info` (bit value 8)
SAP Note [1480644](#) - `gw/acl_mode` versus `gw/reg_no_conn_info` (bit value 16)
SAP Note [1633982](#) - ACCESS option in the file `reginfo` (bit value 32)
SAP Note [1697971](#) - GW: Enhancement when starting external programs (bit value 64)
SAP Note [1848930](#) - GW: Strong `gw/prxy_info` check (bit value 128)
SAP Note [2269642](#) - GW: Validity of parameter `gw/reg_no_conn_info` as of Kernel 7.40
SAP Note [3224889](#) - GW: Change of the default settings for `gw/prxy_info` with parameter `gw/acl_mode_proxy`
WIKI Gateway security settings - extra information regarding SAP note [1444282](#)
<https://wiki.scn.sap.com/wiki/display/SI/Gateway+security+settings+-+extra+information+regarding+SAP+note+1444282>
Blog: [RFC Gateway security, part 4 – prxyinfo ACL](#)
- [8] SNC User's Guide ["S-User" ID and Password required]
<https://sap.com/security> → Security in Detail → Secure User Access → Authentication & Single Sign-On → SNC user's guide
- [9] Secure Store & Forward
- [10] TCP/IP Ports used by SAP

SAP Security Baseline Template

<https://help.sap.com/docs/Security/575a9f0e56f34c6e8138439eefc32b16/616a3c0b1cc748238de9c0341b15c63c.html>

[11] Partner Directories

<https://www.sap.com/partners/find.html>

[12] Integration Scenarios

<https://www.sap.com/partners/partner-program/certify-my-solution/icc-finder.html>

[13] Front-End Network Requirements for mySAP Business Solutions

<https://www.sap.com/about/benchmark/sizing.html>

→ Sizing Guidelines

→ Solutions & Platforms

→ Frontend Network Requirements for SAP Solutions

[14] Security Whitepapers

<https://support.sap.com/securitywp>

Securing Remote Function Calls (RFC), November 2014

https://support.sap.com/content/dam/support/en_us/library/ssp/security-whitepapers/securing_remote-function-calls.pdf

Secure Configuration SAP NetWeaver Application Server ABAP

https://support.sap.com/content/dam/support/en_us/library/ssp/security-whitepapers/secure-config-netweaver-app-server-abap.pdf

[15] Blogs on SCN

Security Patch Process FAQ

<https://scn.sap.com/community/security/blog/2012/03/27/security-patch-process-faq>

How to get RFC call traces to build authorizations for S_RFC for free!

<https://scn.sap.com/community/security/blog/2010/12/05/how-to-get-rfc-call-traces-to-build-authorizations-for-srfc-for-free>

Recommended Settings for the Security Audit Log (SM19 / RSAU_CONFIG / SM20 / RSAU_READ_LOG)

<https://blogs.sap.com/2014/12/11/analysis-and-recommended-settings-of-the-security-audit-log-sm19-sm20/>

How to remove unused clients including client 001 and 066

<https://scn.sap.com/community/security/blog/2013/06/06/how-to-remove-unused-clients-including-client-001-and-066>

or SAP note [1749142](#)

Security of the SAProuter

<https://scn.sap.com/community/security/blog/2013/11/13/security-of-the-saprouter>

Life (profile SAP_NEW), the Universe (role SAP_NEW) and Everything (SAP_ALL)

<https://scn.sap.com/community/security/blog/2014/02/17/life-profile-sapnew-the-universe-role-sapnew-and-everything-sapall>

ABAP Development Standards concerning Security

<https://scn.sap.com/community/security/blog/2010/05/28/abap-development-standards-concerning-security>

Export/Import Critical Authorizations for RSUSR008_009_NEW

<https://scn.sap.com/community/security/blog/2012/08/14/exportimport-critical-authorizations-for-rsusr008009new>

SAP Security Baseline Template

SAP Solution Manager - Configuration Validation WIKI

<https://wiki.scn.sap.com/wiki/display/TechOps/ConfVal+Home>

SAP HANA Audit Trail - Best Practice

https://help.sap.com/docs/SAP_HANA_PLATFORM/b3ee5778bc2e4a089d3299b82ec762a7/35eb4e567d53456088755b8131b7ed1d.html

How to Define Standard Roles for SAP HANA Systems (**broken**)

<https://scn.sap.com/docs/DOC-53974>

Blog: HTTPURLLOC demystified (**broken**)

<https://scn.sap.com/community/netweaver-as/blog/2014/06/04/table-httpurlloc-demystified>

Blog: Using Proxies

<https://wiki.scn.sap.com/wiki/display/BSP/Using+Proxies>

- [16] Documentation: Configuration Table HTTPURLLOC

https://help.sap.com/docs/SAP_NETWEAVER_700/12abecf16c5310148cb8a6bccb9f4277/copye800356cf1834ba1a3f3e756b4acaac8.html?version=7.0.39

- [17] Documentation: Using Configuration Validation for Regular Checks of Compliance

<https://help.sap.com/viewer/bdd095d01c7941c8b5d4c27e04da7315/7.2.10/en-US/d4011b523f0c9e38e10000000a174cb4.html>

- [18] Security Guides for SAP NetWeaver

SAP NetWeaver Security Guide

https://help.sap.com/docs/SAP_NETWEAVER_750/621bb4e3951b4a8ca633ca7ed1c0aba2/4aaf6fd65e233893e10000000a42189c.html

SAP NetWeaver Application Server for ABAP Security Guide

https://help.sap.com/docs/SAP_NETWEAVER_750/864321b9b3dd487d94c70f6a007b0397/4dde53b3e9142e51e10000000a42189c.html

SAP NetWeaver Application Server for Java Security Guide

https://help.sap.com/docs/SAP_NETWEAVER_750/2f8b1599655d4544a3d9c6d1a9b6546b/57d8bfcf38f66f48b95ce1f52b3f5184.html

Examples:

Book	Chapter	Checked 2022-12
ABAP Workbench Tools	ABAP Workbench Tools	7.50
Administration Manual	An Overview of the Security-Related Services	7.02
	Creating a New Connection Entry	7.02
	IIOP Provider Service	7.02
	Java Mail Client Service	7.02
	JCo RFC Provider Service	7.02
	P4 Provider Service	7.02
	Secure Storage Service	7.02
	SSL Provider Service	7.02
	Visual Administrator	7.02
Auditing and Logging	Security Audit Log	7.50

SAP Security Baseline Template

Book	Chapter	Checked 2022-12
Authentication and Single Sign-On	Configuring SAP Systems to Accept and Verify Logon Tickets	7.02
	Configuring the J2EE Engine to Accept Logon Tickets	7.50
	Configuring UME to Use an LDAP Server as Data Source	7.50
Authentication on the Portal	Configuring a Portal Server for SSO with Logon Tickets	7.50
	Single Sign-On	7.50
Background Processing	Background Processing	7.50
	Authorizations for Background Processing	7.50
	Managing Jobs from the Job Overview	7.50
	Standard Jobs	7.50
Change and Transport System	Client Control	7.50
Changing the SAP Standard (BC)	SAP Software Change Registration Procedure (SSCR)	7.50
Collaboration Security Guide	Active Code	7.50
Components of SAP Communication Technology	HTTP Communication Using the SAP System as a Client	broken
	Internet Communication Framework	7.50
	Setting Up Error Pages	7.50
Configuration of Usage Type Process Integration (PI)	Security Configuration at Message Level	7.50
Enabling User Collaboration	Activating Synchronous Collaboration Service Types	7.50
	Configuring Client Browsers to Accept the RTC ActiveX Control	7.02
	Enabling User Collaboration	7.50
	Installing and Configuring Calendar Connectivity	7.50
	Installing and Configuring Lotus Domino Connectivity	7.50
	Installing and Configuring Microsoft Exchange Connectivity	7.50
Identity Management	Configuring Identity Management	7.50
	Configuring the Security Policy for User ID and Passwords	7.02
	Logging and Tracing	7.50
	Logon and Password Security in the ABAP System	7.50
	Password Rules	7.50

SAP Security Baseline Template

Book	Chapter	Checked 2022-12
	<u>Profile Parameters for Logon and Password</u>	7.50
	<u>User Management Engine</u>	7.50
<u>Internet Communication Manager (ICM)</u>	<u>Internet Communication Manager</u>	7.50
<u>Knowledge Management</u>	<u>External Repositories</u>	7.50
	<u>Providing Portal Drive to Client PCs</u>	broken
	<u>WebDAV</u>	7.02
<u>Knowledge Management Security Guide</u>	<u>Further Security-Relevant Information</u>	7.02
	<u>Knowledge Management Security Guide</u>	7.02
<u>Network and Transport Layer Security</u>	<u>Configuring SNC Between the UME and an ABAP-Based System</u>	7.02
	<u>Configuring SSL Between the UME and an LDAP Directory</u>	7.02
	<u>Configuring the SAP Web AS for Supporting SSL</u>	broken
	<u>Configuring the Use of SSL on the J2EE Engine</u>	broken
	<u>Creating an SNC PSE for the SAP J2EE Engine</u>	7.02
	<u>Deploying the SAP Java Cryptographic Toolkit</u>	7.02
	<u>Destination Service</u>	7.02
	<u>Maintaining HTTP and Web Service Destinations</u>	7.02
	<u>Maintaining RFC Destinations</u>	7.02
	<u>Managing Cryptography Providers</u>	7.02
<u>Portal</u>	<u>Creating iViews for Databases (JDBC)</u>	broken
	<u>Creating SAP Application iViews</u>	broken
	<u>Creating Web Dynpro Java iViews</u>	broken
	<u>Creating Web-based URL iViews</u>	broken
	<u>Creating XML iViews</u>	broken
	<u>Editing HTTP System Properties</u>	broken
	<u>Editing JDBC System Properties</u>	broken
	<u>Editing SAP System Properties</u>	broken
	<u>iViews</u>	broken
	<u>Pre-configured Roles</u>	broken
	<u>Security Zones</u>	broken
	<u>System landscape</u>	broken
	<u>System Properties for Proxy Server</u>	broken
<u>Portal Security Guide</u>	<u>Dispensable Functions with Impacts on Security</u>	7.02

SAP Security Baseline Template

Book	Chapter	Checked 2022-12
	Network and Communication Security (Portal)	7.02
	Portal Security Guide	7.02
	User Management	7.02
Running an Enterprise Portal	Creating Web Dynpro ABAP iViews	broken
SAP Gateway	SAP Gateway	broken
SAP NetWeaver Application Server ABAP Security Guide	As of Release 4.0	broken
	Protecting Special Users	7.50
	Protecting Your Productive System (Change & Transport System)	7.02
	User Types	7.02
SAP NetWeaver Application Server Java Security Guide	Authorizations	7.02
	Standard User Groups	7.02
	Standard Users	broken
SAP NetWeaver Exchange Infrastructure	Communication Channel Configuration	7.02
	Communication Channel Configuration RNIF	7.02
	Communication Channel Configuration RNIF 2.0	7.02
	Communication Channel Configuration Sender	7.02
	Configuring a Communication Channel for single-action initiator	7.02
	Configuring a Communication Channel for single-action responder	7.02
	Configuring a Communication Channel for two-action initiator	7.02
	Configuring a Communication Channel for two-action responder	7.02
	Configuring the Receiver File/FTP Adapter	7.02
	Configuring the Receiver JDBC Adapter	broken
	Configuring the Receiver JMS Adapter	7.02
	Configuring the Receiver Mail Adapter	7.02
	Configuring the Receiver Marketplace Adapter	7.02
	Configuring the Receiver RFC Adapter	7.02
	Configuring the Receiver SAP Business Connector Adapter	7.02
	Configuring the Receiver SOAP Adapter	broken
	Configuring the Sender File/FTP Adapter	7.02

SAP Security Baseline Template

Book	Chapter	Checked 2022-12
	Configuring the Sender JDBC Adapter	7.02
	Configuring the Sender JMS Adapter	broken
	Configuring the Sender Mail Adapter	broken
	Configuring the Sender Marketplace Adapter	7.02
	Configuring the Sender Plain HTTP Adapter	7.02
	Configuring the Sender RFC Adapter	7.02
	Configuring the Sender SAP Business Connector Adapter	7.02
	Configuring the Sender SOAP Adapter	broken
	Configuring the Sender XI Adapter	broken
	IDoc Adapter	7.02
	JDBC Adapter	7.02
	JMS Adapter	7.02
	Marketplace Adapter	7.02
	Plain HTTP Adapter	7.02
	RFC Adapter	7.02
	RNIF Adapters	7.02
	SAP Business Connector Adapter	7.02
	Security Services in the RNIF Adapter 1.1	7.02
	Security Services in the RNIF Adapter 2.0	7.02
	Single-Action Initiator	7.02
	Single-Action Responder	7.02
	SOAP Adapter	7.02
	XI Adapter	broken
SAP NetWeaver Process Integration Security Guide	CIDX Adapter	broken
	File/FTP, JDBC, JMS, and Mail Adapters	broken
	Message-Level Security	broken
	Network and Communication Security	broken
	RFC and SNC	broken
	RosettaNet RNIF Adapters	broken
	Service Users for Internal Communication	broken
	Service Users for Message Exchange	broken
	Technical Communication	broken
	Security Guide for SAP NetWeaver 6.40	broken

SAP Security Baseline Template

Book	Chapter	Checked 2022-12
SAP NetWeaver Security Guide	Security Guide for SAP NetWeaver 7.0	broken
	Security Guides for Usage Types EPC and EP	7.02
SAP Web Dispatcher	is/HTTP/show_detailed_errors	broken
	Metadata Exchange Using SSL	broken
SAPconnect (BC-SRV-COM)	Secure Email	broken
SAProuter	Route Table Examples	broken
	SAProuter	broken
	SAProuter Options	broken
Search	Configuration of the TREX Security Settings	broken
	Configuring TREXNet for Secure Communication	broken
Search and Classification (TREX) Security Guide	Search and Classification (TREX) Security Guide	broken
Secure Programming	Password Security	7.02
	Secure Programming - ABAP	7.02
Security Guide for Connectivity with the J2EE Engine	Configuring the J2EE Engine for IIOP Security	7.02
Security of the SAP NetWeaver Development Infrastructure	File Access Rights for the NWDI Transport Directory	broken
	Working with the SDM	broken
System Security	Key Storage Service	7.02
	Secure Storage (ABAP)	broken
Technical Operations Manual for mySAP Technology	The PSE Types	4.70
User Authentication and Single Sign-On	Authentication on the AS Java	broken
	Authentication Schemes	7.02
	Login Modules	7.02
Using Java	Creating JCo Destinations	broken
	Custom Error Pages	7.02
	Default Configurations of the Web Container	7.02
	Java Messaging	7.02
	Remote Authentication	7.02
	RMI-IIOP	7.02
	RMI-P4	broken

SAP Security Baseline Template

Book	Chapter	Checked 2022-12
	<u>Setting Up the Development Landscape: Landscape Configurator</u>	broken
	<u>Transports with the NWDI: Transport Studio</u>	7.02
	<u>UME Properties for the Security Policy</u>	7.02
	<u>User Authorization in the Design Time Repository</u>	broken
	<u>Using P4 Protocol Over a Secure Connection</u>	broken
	<u>Version Control</u>	broken
	<u>Web Dynpro Architecture</u>	broken
	<u>Web Dynpro Content Administrator</u>	broken
Using the SAP Cryptographic Library for SNC	<u>Using the SAP Cryptographic Library for SNC</u>	4.70
Working with Folders in Windows (Portal Drive)	<u>Working with Folders in Windows (Portal Drive)</u>	broken

SAP Security Baseline Template

6 Index

Authorization objects

B_ALE_RECV	47
S_DATASET	15
S_DBCON	31
S_DBG	30
S_DEVELOP	30
S_ICF	29
S_PATH	15
S_PROGRAM	30
S_QUERY	30
S_RFC	30, 78
S_RFC_ADM	30
S_RFC_ADM_TT	28
S_RFCACL	28, 29
S_SCR	53
S_SERVICE	30
S_SPO_ACT	30
S_START	20, 30, 67
S_TABU_DIS	30, 31, 41
S_TABU_NAM	30, 31
S_TABU_SQL	31
S_TCODE	30
S_USER_GRP	30

Authorization profiles

S_A.TMSADM	22
SAP_ALL	21, 30, 41, 78
SAP_NEW	30, 41, 43, 78

BTP

Beta features	20, 46
Business user	22
Cloud Connector	17, 20, 36, 73, 74
Cloud Foundry	23, 30, 31

Directory	22
Global account	22, 29, 30, 42, 59
Identity Provider	22, 30
Multi environment	23
Neo environment	23, 31, 32, 42
Platform user	22, 23, 29
Public user	59
Subaccount	17, 20, 22, 23, 29, 30, 31, 32, 36, 42, 46

BTP role collections

Directory Administrator	31
Global Account Administrator	31
Subaccount Administrator	31

BTP roles

AccountDeveloper	31, 42
Administrator	31, 42

BTP scopes

Manage Account Members	32, 43
Manage Audit Logs	32, 43
Manage Authorization	32, 43
manageCustomPlatformRoles	31, 42

Clickjacking Framing Protection

000	21
001	18, 49
066	18, 22, 49

Configuration Stores

ABAP_INSTANCE_PAHI	40
CLIENTS	39
LOGGED_TABLES	40
TDDAT	40
TRANSPORT_TOOL	41

SAP Security Baseline Template

CSS Style Sheet	67	listeninterface.....	17
Customizing		maximum_invalid_connect_attempts	27
BNAME_RESTRICT.....	23, 66	maximum_password_lifetime.....	26
REF_USER_CHECK.....	22, 66	maximum_unused_initital_password_l ifetime	52
US_ASGM_TRANSPORT.....	32, 66	maximum_unused_initial_password_ lifetime.....	26, 52
USER_REL_IMPORT.....	32, 66	maximum_unused_productive_passwo rd_lifetime.....	26
Emergency users.....	37	minimal_password_length.....	26, 52
Files		minimum_password_lifetime.....	27
prxyinfo	28, 53	password_expire_warning_time.....	27
reginfo.....	27, 77	password_layout.....	26
secinfo.....	27, 77	password_lock_for_system_user ..	27
Functions		password_lock_time.....	27
SACF_SET_SBD.....	19	HANA system privileges	
SECSTORE_KEY_WIZARD_RFC	53	DATA ADMIN.....	31
HANA audit targets		HTML application descriptors	
CSTABLE.....	34	neo-app.json.....	31, 42
CSVFILE.....	34	HTML5 permissions	
SYSLOGPROTOCOL.....	34	NonActiveApplicationPermission	31, 42
HANA auditing	67	Identity Provider	29
HANA parameter files		Java profile parameters	
global.ini	34	service/protectedwebmethods ..	14, 45
indexserver.ini.....	19, 26, 52	Java properties	
HANA parameter sections		enable.xml.hardener	34
auditing configuration.....	34	EnableInvokerServletGlobally	18, 49
communication	17	SystemCookiesDataProtection.....	19
global.ini	17	SystemCookiesHTTPSProtection.....	19
internal_hostname_resolution	17	UseServerHeader.....	14, 45
password policy.....	26, 52	Java services	
sqltrace	19	servlet_jsp	18, 49
HANA parameters		Java user groups	
default_audit_trail_type.....	34	Administrators	31
force_first_password_change ..	26, 52		
global_auditing_state	34		
last_used_passwords.....	26		
level	19		

SAP Security Baseline Template

SAP_J2EE_ADMIN.....	31	Note 1414256.....	22
Notes		Note 1417568.....	16
Note 1916	13	Note 1422273.....	16
Note 64016	77	Note 1422273.....	17
Note 65968	30	Note 1434117.....	77
Note 84052	67	Note 1439348.....	45
Note 110612	77	Note 1444282.....	77
Note 510007	24, 48, 64	Note 1445998.....	49
Note 513694	66	Note 1458262.....	25
Note 515130	19	Note 1465129.....	77
Note 515130	68	Note 1473017.....	77
Note 571276	32, 39, 66	Note 1480644.....	77
Note 618516	77	Note 1484692.....	42
Note 626073	17	Note 1487606.....	47
Note 626073	16, 17	Note 1487606.....	17
Note 626073	17	Note 1497003.....	15, 37
Note 626073	17	Note 1531399.....	29, 66
Note 634262	15	Note 1591259.....	25
Note 862989	24, 25, 67	Note 1616535.....	15, 44
Note 866732	77	Note 1633982.....	77
Note 870127	44, 46	Note 1690662.....	48
Note 887164	17	Note 1697971.....	77
Note 910918	53, 77	Note 1712860.....	17
Note 927637	45	Note 1723881.....	32, 39, 66
Note 979467	17	Note 1723881.....	19
Note 1023437	25, 68	Note 1731549.....	66
Note 1036936	77	Note 1731549.....	23, 57
Note 1042274	67	Note 1749142.....	49
Note 1157137	19, 57	Note 1749142.....	78
Note 1277022	29, 68	Note 1784800.....	13, 67
Note 1298433	77	Note 1823687.....	44
Note 1322944	64	Note 1848930.....	53, 77
Note 1394100	17	Note 1902258.....	32
Note 1399324	19, 57	Note 1902611.....	32, 53
Note 1413011	20	Note 1922712.....	67

SAP Security Baseline Template

Note 1956086	19, 57	Note 2565390.....	18
Note 2001962	14, 67	Note 2579165.....	25, 69
Note 2012562	15	Note 2614667.....	16
Note 2040644	24, 48, 67	Note 2634476.....	15
Note 2052899	15	Note 2656696.....	15
Note 2065596	64	Note 2666331.....	55
Note 2068872	19, 29	Note 2671160.....	13, 41, 64, 67
Note 2119087	57	Note 2676384.....	69
Note 2119627	55	Note 2678501.....	16, 69
Note 2122578	48	Note 2713544.....	65
Note 2140269	26, 68	Note 2714839.....	66, 68
Note 2159014	66	Note 2776748.....	27, 68
Note 2159014	44	Note 2788140.....	17, 68, 69
Note 2183363	17	Note 2794817.....	68
Note 2190621	33	Note 2838480.....	69
Note 2206951	44	Note 2838788.....	45
Note 2216306	16, 68	Note 2926224.....	17, 19, 33, 66, 68
Note 2251231	15	Note 2926224.....	2
Note 2260323	15	Note 2934135.....	64
Note 2269642	77	Note 2948239.....	17
Note 2288631	64	Note 2958356.....	68
Note 2293011	55	Note 2975959.....	66, 67
Note 2296251	18	Note 2999707.....	19
Note 2296271	13	Note 2999707.....	57
Note 2308217	17	Note 3016478.....	34
Note 2362078	24, 48	Note 3016478.....	67
Note 2372626	34	Note 3064888.....	20, 67
Note 2384290	48	Note 3083852.....	67
Note 2395138	15	Note 3089413.....	57
Note 2441606	69	Note 3093760.....	67
Note 2449757	16, 64	Note 3157268.....	28, 29, 66
Note 2486668	57	Note 3198351.....	66
Note 2551541	15	Note 3213711.....	67
Note 2562089	15, 64	Note 3224889.....	53, 77
Note 2562127	64	Note 3224889.....	28

SAP Security Baseline Template

Note 3224889	66
Note 3250501	2, 69
Note 3272585	16
Note 3286256	15
Note 3303172	21
Note 3346659	24, 48
Note 3381209	69
Note 3480723	69
Note 3581719	33
Note 3584984	29
Note 3600840	20

Policy Attributes

CHECK_PASSWORD_BLACKLIST...	25, 26, 51
DISABLE_PASSWORD_LOGON.....	25, 51
DISABLE_TICKET_LOGON.....	25, 26, 51
MAX_FAILED_PASSWORD_LOGON_ATTEMPTS	25, 51
MAX_PASSWORD_IDLE_INITIAL.	24, 50, 51
MAX_PASSWORD_IDLE_PRODUCTIVE	25, 51
MIN_PASSWORD_CHANGE_WAITTIME	25, 51
MIN_PASSWORD_DIFFERENCE	25, 51
MIN_PASSWORD_DIGITS	25, 51
MIN_PASSWORD_LENGTH.....	24, 50, 51
MIN_PASSWORD_LETTERS.....	25, 51
MIN_PASSWORD_LOWERCASE.....	25, 51
MIN_PASSWORD_SPECIALS	25, 51
MIN_PASSWORD_UPPERCASE.....	25, 51
PASSWORD_CHANGE_FOR_SSO	25, 51
PASSWORD_CHANGE_INTERVAL...	25, 50, 51
PASSWORD_COMPLIANCE_TO_CURRENT_POLICY.....	25, 51
PASSWORD_HISTORY_SIZE	25, 51
PASSWORD_LOCK_EXPIRATION.....	25, 51
SERVER_LOGON_PRIVILEGE.....	51
TENANT_RUNLEVEL_LOGON_PRIVILEGE	51

Portal properties

portal.alias.security.enforce_secure_cookie.....	29
--	----

Profile parameters

abap/ext_debugging_possible..	13, 70
abap/path_norm_Windows	15
abap/path_normalization.....	15
auth/check/calltransaction ..	19, 68, 70
auth/no_check_in_some_cases..	19, 69
auth/object_disabling_active	19, 68
auth/rfc_authority_check...	16, 68, 70
dba/dba/ccms_maintenance	13, 70
dba/dba/ccms_security_level..	14, 70
dynp/checkskip1screen	19, 57
dynp/confirmskip1screen.....	19, 57
gw/acl_mode	28, 77
gw/acl_mode_proxy..	28, 53, 66, 67, 70, 77
gw/monitor.....	28
gw/prxy_info.....	28, 53, 77
gw/reg_info	27
gw/reg_no_conn_info	27, 68, 77
gw/rem_start.....	28, 68, 70
gw/sec_info	27
gw/sim_mode	28
icf/log/active	66
icf/reject_expired_passwd.	25, 67, 70
icf/set_HTTPonly_flag_on_cookies	29, 68
icm/accept_forwarded_cert_via_https.....	15
icm/HTTP/admin_<num>.....	15, 24
icm/HTTP/auth_<xx>.....	14, 44
icm/HTTP/error_tmpl_path.....	15, 44
icm/HTTP/logging_	68
icm/HTTP/logging_0.....	33

SAP Security Baseline Template

icm/HTTP/logging_client_.....	68	login/password_hash_algorithm..	26, 68
icm/HTTP/logging_client_0.....	33	login/password_history_size..	25, 51
icm/security_log.....	33, 68	login/password_logon_usergroup	26
icm/server_port_<num>.....	24, 49	login/password_max_idle_initial.....	24, 50, 51, 67
icm/SMTP/show_server_header.....	14	login/password_max_idle_productive.....	25, 51, 67
icm/trace_secured_data.....	15	login/show_detailed_errors..	14, 44, 67
icm/trusted_reverse_proxy_<num>.....	15	login/show_detailed_errors.....	70
is/HTTP/show_detailed_errors	14, 44	login/ticket_only_by_https....	29, 66
is/HTTP/show_server_header.....	14	login/ticket_only_to_host.....	29
ixml/dtd_restriction.....	17	ms/acl_info.....	16, 28
login/accept_sso2_ticket.....	29	ms/admin_port.....	16
login/disable_cplic.....	17, 68, 70	ms/HTTP/logging_0.....	33, 68
login/disable_password_logon....	25, 26, 51	ms/http_logging.....	33, 68
login/failed_user_auto_unlock..	25, 51	ms/monitor.....	16
login/fails_to_user_lock.....	25, 51	ms/server_port_<xx>.....	16
login/min_password_diff.....	25, 51	rdisp/gui_auto_logout.....	69
login/min_password_digits.....	25, 51	rdisp/msserv_internal.....	16
login/min_password_letters....	25, 51	rdisp/TRACE_HIDE_SEC_DATA.....	15, 70
login/min_password_lng.....	24, 50, 51	rdisp/vbdelete.....	19, 58, 69
login/min_password_lowercase	25, 51	rec/client.....	13, 40, 41, 67
login/min_password_specials..	25, 51	rfc/allowoldticket4tt.....	29, 66, 70
login/min_password_uppercase	25, 51	rfc/authCheckInPlayback.....	20
login/no_automatic_user_sapstar.....	21	rfc/callback_security_method....	16, 69, 70
login/password_change_for_SSO..	25, 51	rfc/log/active.....	66
login/password_change_waittime	25, 51	rfc/reject_expired_passwd..	25, 69, 70
login/password_compliance_to_current_policy.....	25, 51, 67	rfc/selftrust.....	16, 28
login/password_downwards_compatibility.....	25, 51, 52, 68	rsau/enable.....	33
login/password_expiration_time	25, 50, 51	rsau/integrity.....	33
		rsau/log_peer_address.....	33
		rsau/selection_slots.....	33
		rsau/user_selection.....	33, 37

SAP Security Baseline Template

rsec/securestorage/keyfile	54	RDDTDDAT_BCE.....	40
sapgui/nwbc_scripting.....	18	RSAU_READ_LOG	37
sapgui/user_scripting.....	18, 53, 70	RSAU_SELECT_EVENTS.....	37
sapgui/user_scripting_disable_re cording.....	18	RSEC_KEY_WIZARD.....	32, 53
sapgui/user_scripting_force_noti fication.....	18	RSPFRECOMMENDED.....	65
sapgui/user_scripting_per_user	18,	RSUSR003	55
53		RSUSR008_009_NEW	78
sapgui/user_scripting_set_readon ly.....	18	ZRSPFPAR_DYNAMIC_CD	16
service/protectedwebmethods..	14, 44	Roles	
snc/accept_insecure_cplic.....	48	SAP_NEW.....	30, 41, 78
snc/accept_insecure_gui	24, 48	SACF	19, 58, 68
snc/accept_insecure_r3int_rfc...	48	SACF Scenarios	
snc/accept_insecure_rfc	24, 48	BC_GENERIC_REPORT_START.....	19
snc/data_protection/max	24, 48	BC_GENERIC_REPORT_START_BATCH..	19
snc/data_protection/min	23	FIN_PARL_ACCTG_LEDGER	19
snc/data_protection/use	24, 48	SACF_DEMO_SCENARIO.....	19
snc/enable	23, 47	sapstartsrv.....	14
snc/log_unencrypted_rfc	24, 48	Security Audit Log	
snc/only_encrypted_gui.....	24, 48	Even EUP.....	21
snc/only_encrypted_rfc.....	24, 48	Event BUJ	48
snc/permit_insecure_start.	24, 48, 70	Event CUQ	15
ssl/ciphersuites	24, 48, 66, 67	Event CUR	15
ssl/client_ciphersuites	24, 48, 67	Event CUS	15
system/secure_communication.	16, 24,	Event CUT	15
48, 67		Event DU5	15
wdisp/add_xforwardedfor_header	17,	Event EU4	15
69		Self-registration	21
wdisp/filter_internal_uris	46	SFILE Parameters	
wdisp/permission_table.....	14, 44	REJECT_EMPTY_PATH.....	15
UNCONF_PATH_AS_EMPTY.....		15	
Protocols		SLDW	19, 58
P4	49	SLDW allowlist	
SMTP	49	BC_CHECK_EXT_SKIP_FIRST_SCREEN	58
Reports		Software Provisioning Manager (SWPM)	65
RDDPRCHK	40	Software Update Manager (SUM)	65

SAP Security Baseline Template

Standard users

CONTENTSERV	22, 55
DBACOCKPIT	52
DDIC	21, 33, 37
EARLYWATCH	22
SAP*	21, 33, 37
SAP<SID>	52
SAPCPIC	21, 33
SAPSUPPORT	22, 37, 55
SAPSYS	37
SMD_ADMIN	22, 55
SMD_AGT	22, 55
SMD_BI_RFC	22, 55
SMD_RFC	22, 55
SMDAGENT_<SAPSolutionManagerSID>	22, 55
SOLMAN_ADMIN	22, 55
SOLMAN_BTC	22, 55
SYSTEM	22, 52, 55, 56
TMSADM	21, 22

Support users.....37

Switchable authorization check framework 19, 58, 68

Table authorization groups

SPWD	31
------------	----

Tables

FILECMCUSTP	15
HTTPURLLOC	29
PRGN_CUST	22, 23, 32, 66
SPTH	15
T000	13
TADIR	13
TPSYSTEMDEFAULT	41
USH02	31
USR02	25, 31

USR40	25, 26
USRPWDHISTORY	31
V_TSTCS	58

Transactions

RSAU_CONFIG	33, 78
RSAU_READ_LOG	37, 78
RZ10	16
RZ11	16, 65
SACF_COMPARE	19, 58
SCC4	13
SE06	13
SE11	40
SE13	40
SE16	31, 40
SE16N	31
SECPOL	51
SECSTORE	32, 53
SFILE	15
SLDW	58, 67
SLDW_COMPARE	19, 58
SM19	33, 78
SM20	37, 78
SM21	16
SM30	31
SMMS	16
STDDAT	40
STMS	41
SU25	20
SUIM	37

Transport parameters

RECCLIENT	13, 40, 67
TLOGOCHECK	13, 41, 67
TP_RELEASE	13, 41
TP_VERSION	13, 41
VERS_AT_EXP	13, 41

SAP Security Baseline Template

VERS_AT_IMP	13, 41, 67	ume.logon.security_policy.passwo	
Trusted Network Zone.....	67	rd_max_idle_time.....	26
UCON	17	ume.logon.security_policy.passwo	
UME properties		rd_min_length.....	26
login.ticket_lifetime.....	29	ume.logon.security_policy.passwo	
ume.logon.httponlycookie.....	29	rd_mix_case_required.....	26
ume.logon.security.enforce_secur		ume.logon.security_policy.passwo	
e_cookie.....	29	rd_special_char_required.....	26
ume.logon.security_policy.oldpas		ume.logon.security_policy.userid	
s_in_newpass_allowed.....	26	_in_password_allowed.....	26
ume.logon.security_policy.passwo		ume.logon.selfreg.....	55
rd_alpha_numeric_required.....	26	User groups	
ume.logon.security_policy.passwo		SUPER.....	21
rd_expire_days.....	26	User type L	22
ume.logon.security_policy.passwo		Users	
rd_history.....	26	SAPCPIC.....	43
		SAPJSF	43

